



Argus – LLM driven Cyber Security Executive Reporting Platform

A Proof of Concept for Summarizing XDR Alerts Using Elastic Rules and
Local LLMs

Flynn Chambers

20160328

Index

Abstract.....	5
1. Introduction.....	6
1.1 Statement of the IT Challenge	6
1.2 Objectives and Scope.....	7
1.3 Methodological Overview	7
1.4 Structure of the Report.....	7
2. Literature Review.....	8
2.1 AI Integration in Cybersecurity Operations	8
2.2 LLMs and Threat Intelligence	9
2.3 Data Quality and the Role of Ticketing Systems	11
2.4 False-Positive and False-Negative Reduction	12
2.5 Business Decision-Making and Executive Reporting.....	13
2.6 Security Automation and the MSP Context	14
2.7 Identification of Gaps and Justification for the Study	15
2.8 Summary of Thematic Insights	15
2.9 Evaluation of Benchmarking Tools and Datasets	16
2.8 Summary of Thematic Insights	16
2.9 Evaluation of Benchmarking Tools and Datasets	17
2.10 Theoretical Framing: Design Science Research (DSR).....	18
2.11 Literature Review Limitations	19
3. Methodology and Ethics	20
3.1 Research Design.....	20
Cycle 1 – Data Source Exploration.....	21
Cycle 2 – Synthetic Alert Dataset Generation	22
Cycle 3 – Alert Normalisation and Enrichment.....	22
Cycle 4 – Retrieval-Augmented Summarisation Pipeline (Proof of Concept)	23
3.2 Ethical Safeguards and Data Handling	24
Use of Synthetic Data Only:	24
On-Premise Execution:	24
Model Selection and Auditability:	24
Post-Processing and Hallucination Detection:.....	24
Voluntary Evaluation Planning (Not Implemented):	25

Research Transparency:	25
3.3 Justification of Chosen Methods.....	25
3.4 Ethical Approvals and Conditions	26
4. Application.....	27
4.1 Implementation Process	27
Synthetic Alert Generation.....	27
Alert Normalisation and Enrichment	28
Detection Rule Parsing and Embedding	28
RAG-Based Summarisation Architecture	29
Data Flow and Component Overview.....	29
Rationale for Local Execution	30
4.2 Evaluation and Testing.....	30
Validation Methodology.....	30
Summary Accuracy and Interpretability	31
Multi-Level Summary Coherence.....	31
Hallucination Control and Review Flagging	31
Limitations of Evaluation	32
4.3 Challenges and Mitigations.....	32
GPU Constraints and Model Selection	32
False Positives and Noise in Alert Generation.....	33
Schema Normalization Across Vendors.....	33
Detection Rule Matching and Coverage Gaps.....	33
LLM Hallucinations and Output Validation	33
Summary	34
5. Results and Analysis	34
5.1 Presentation of Findings	34
Alert Coverage and Summary Quality.....	35
Executive-Level Takeaways	35
LLM Responsiveness and Summary Consistency	37
5.2 Critical Analysis: Comparison with Existing Techniques.....	37
Contextual Depth and Semantic Enrichment.....	37
Executive Relevance and Clarity	37
Platform Independence and Schema Flexibility	38

Limitations and Realism Trade-Offs.....	38
5.3 Summary of Key Findings.....	39
High-Fidelity Alert Grouping Enables Contextual Summarisation	39
Strong Alignment with Known Detection Logic	39
Executive Takeaway Generation Is Viable Using Local Models.....	39
Operational Viability on Modest Infrastructure	39
Hallucination Controls Were Effective But Require Further Development	39
Cross-Platform Schema Normalisation Was a Key Enabler	40
Synthetic Data Permitted Broad and Controlled Evaluation	40
5.4 Critical Comparison with Existing Techniques	40
Comparison with Commercial SIEM Dashboards.....	40
Comparison with LLM-Based Research Prototypes.....	40
Strengths over Static Report Generators.....	41
Limitations Compared to Enterprise-Scale AI Systems.....	41
5.5 Summary	41
6. Discussion	42
6.1 Interpretation of Findings	42
6.2 Critical Evaluation of Novelty, Strengths and Limitations	43
Novelty.....	43
Strengths	44
Limitations	44
6.3 Legal, Cultural and Ethical Considerations	44
6.4 Implications.....	45
Operational Implications for MSPs	45
Implications for Security Product Development.....	46
Strategic Implications for AI Governance	46
Research and Academic Implications	46
Summary	46
7. Conclusion and Recommendations.....	47
7.1 Summary of Key Findings	47
7.2 Contributions of the Research.....	48
7.3 Recommendations.....	49
Evaluate Against Real-World Data	49

Introduce Human-in-the-Loop Feedback.....49

Expand LLM Capacity Where Possible.....49

Incorporate Continuous Telemetry Ingestion.....49

Support Multilingual and Localised Outputs.....49

Benchmark Against Commercial Reporting Tools50

Expand Correlation Capabilities50

7.4 Future Work50

Real-World Dataset Integration50

User-Centred Evaluation Studies50

Higher-Capacity Model Deployment.....50

Real-Time Summarisation Pipeline50

Custom Prompt Engineering Framework50

Explainability Visualisation Layer.....51

Cross-Platform Production Deployment.....51

Policy and Compliance Integration.....51

7.5 Final Concluding Statement.....52

Abstract

This research project addresses a growing problem in the cybersecurity operations domain: the lack of concise, actionable, and executive-readable summaries of cybersecurity alerts generated by modern Extended Detection and Response (XDR) platforms. While these platforms generate high volumes of telemetry, the outputs are often inaccessible to executive stakeholders due to their technical complexity, inconsistent schemas, and lack of contextual relevance. Managed Service Providers (MSPs), in particular, face increasing pressure to deliver clear threat intelligence across client environments-yet most lack the tooling to automate this translation from raw telemetry into meaningful summaries.

Recent advancements in large language models (LLMs) have shown potential in natural language summarisation, but their adoption in operational security contexts remains limited. Privacy concerns, hallucination risk, poor explainability, and over-reliance on cloud-based APIs constrain their applicability-especially within environments that handle sensitive client data. Additionally, few publicly available datasets exist that model high-fidelity multi-platform XDR alerts with contextual metadata, making it difficult to experiment with or evaluate LLM-based summarisation tools under controlled conditions.

This project proposes a Retrieval-Augmented Generation (RAG) summarisation system that operates entirely in a local, privacy-respecting environment. The solution was built using open-source tooling and deployed against a synthetic dataset of 10,000 alerts generated across multiple vendor schemas, including Elastic, SentinelOne, Microsoft Defender, CrowdStrike, and Carbon Black. Each synthetic alert was enriched with MITRE ATT&CK mappings, simulated user and host data, and platform-specific field structures (Elastic Security, n.d.). The data was normalised to a unified schema and grouped into summarisation clusters based on user, host, and tactic.

A local instance of OpenLLaMA-7B-chat, quantised for GPU efficiency, served as the language model. It was integrated with a FAISS-based vector search index built from Elastic Security's open-source detection rules. This retrieval layer ensured that each summarisation prompt was grounded in semantically similar rule content, providing both factual support and traceability. Summaries were produced with embedded uncertainty qualifiers and inline provenance, aiming to bridge the gap between technical detection and executive interpretation.

The project adopted a Design Science Research (DSR) methodology (Hevner et al., 2004), iteratively building and evaluating the system through four distinct cycles. Evaluation metrics focused on schema normalisation success, summarisation quality, grounding accuracy, and hallucination risk. From the initial 10,000-alert corpus, 9,820 alerts were successfully normalised. For summarisation, a 1,000-alert subset was used due to GPU constraints. A hallucination guard flagged only three summaries for ungrounded numeric content, suggesting strong alignment with retrieved rules.

This work contributes a modular architecture for local, explainable cybersecurity alert summarisation using open-source LLMs and RAG principles. It demonstrates that

meaningful, executive-level reporting is feasible even under strict data constraints, provided that robust preprocessing and grounding mechanisms are in place. The solution may inform future research and product development in privacy-sensitive MSP and enterprise environments, where trust, traceability, and readability are critical.

1. Introduction

Cybersecurity telemetry has become increasingly dense and voluminous due to the widespread deployment of Extended Detection and Response (XDR) platforms. These platforms consolidate endpoint, identity, and network data into a single threat detection stream, providing security analysts with unprecedented visibility. However, this visibility does not scale linearly into actionable understanding-particularly for executive stakeholders. Security operations centres (SOCs), and especially Managed Service Providers (MSPs), are burdened with the challenge of translating this technical data into business-relevant narratives.

The problem is compounded by the diversity of alert schemas, limited cross-platform standardisation, and the absence of tools that can generate summarised, context-rich reports from raw detection events. Executive teams require concise and comprehensible overviews of cyber risk, not raw JSON logs or SIEM dashboards saturated with false positives. Yet most reporting remains reactive, manual, and disconnected from the nuances of the underlying telemetry.

This research addresses the disconnect by designing and evaluating a Retrieval-Augmented Generation (RAG) summarisation pipeline that can convert heterogeneous alert data into structured summaries suitable for executive reporting. Built entirely within a local, privacy-preserving environment, the solution leverages synthetic XDR telemetry and open-source detection rules to test a proof of concept. The system uses a local LLaMA 3 7B-chat model for summarisation, paired with a FAISS-based semantic retrieval layer to ensure that outputs are grounded in known detection logic.

The core research question guiding this project is: *Can a local, RAG-based architecture generate accurate, readable, and explainable summaries from XDR telemetry in a format suitable for executive consumption?* This question sits at the intersection of cybersecurity, machine learning, and human-centred reporting, aiming to close a gap in existing practices where LLMs are rarely deployed for operational summarisation under strict privacy and performance constraints.

1.1 Statement of the IT Challenge

Modern cybersecurity systems generate vast volumes of telemetry across endpoint, cloud, identity, and network surfaces. The challenge lies not in detection, but in interpretation-particularly for non-technical audiences. MSPs are contractually and operationally responsible for informing clients of incidents, trends, and risks. However, most reports produced are either too technical, too verbose, or lack sufficient grounding in business

context. Manual reporting is labour-intensive and unscalable, and automation efforts often fail to produce executive-friendly narratives that combine precision, trust, and clarity.

1.2 Objectives and Scope

This research seeks to design and evaluate a local pipeline that can transform synthetic cybersecurity alerts into accurate and readable executive summaries. Specific objectives include:

- Constructing a realistic synthetic dataset representing XDR alerts from multiple vendors
- Developing a semantic retrieval system based on Elastic's detection rules and FAISS
- Integrating a quantised local instance of LLaMA 3 7B-chat for grounded summarisation
- Evaluating the system's ability to generate concise, trustworthy summaries using non-production data

The project scope is deliberately constrained to lab-based experimentation with synthetic data. It does not involve production telemetry or interaction with real-world MSPs. The focus is on technical feasibility and architecture design.

1.3 Methodological Overview

The project follows a Design Science Research (DSR) methodology, structured into four iterative build-and-evaluate cycles. Each cycle contributed to a different subsystem of the architecture, from alert generation to summarisation. A modular pipeline was built using Python, FAISS, sentence-transformers, and TOML-based parsing logic (Elastic Security, n.d.). LLM summarisation was grounded using semantic retrieval to mitigate hallucination risk and improve interpretability. Evaluation focused on transformation accuracy, schema compliance, and summarisation quality under constrained compute.

1.4 Structure of the Report

- Chapter 2 reviews the academic and industry literature relevant to LLM summarisation, XDR analytics, schema normalisation, and executive reporting in cybersecurity.
- Chapter 3 details the methodology, tools, and ethical safeguards employed.
- Chapter 4 documents the implementation process, challenges encountered, and architectural decisions made.
- Chapter 5 presents and analyses the results of the summarisation pipeline.
- Chapter 6 discusses the broader implications, strengths, and limitations of the solution.

- Chapter 7 concludes the report and provides recommendations for future research and development."

2. Literature Review

This chapter critically evaluates contemporary academic research and state-of-the-art practice relevant to the development of an AI-driven cybersecurity reporting solution centred on a Retrieval-Augmented Generation (RAG) pipeline. Given the project's grounding in operational cybersecurity workflows and executive reporting needs, the review spans both foundational research and emerging applications across several intersecting domains.

The literature is organised into six thematic areas that reflect the core objectives of the project: (1) AI integration in cybersecurity operations, (2) large language models (LLMs) and threat intelligence, (3) data quality and ticketing systems, (4) false-positive and false-negative reduction, (5) business decision-making and executive reporting, and (6) security automation in the Managed Service Provider (MSP) context. These categories were selected to align with the practical challenges encountered during the system's development and to map directly onto the architectural and methodological choices made.

Across each section, the review synthesises findings from peer-reviewed academic sources, industry white papers, and relevant standards bodies. It highlights methodological trends, tool adoption patterns, and implementation challenges. Importantly, it identifies recurring gaps—such as the lack of multi-platform executive reporting pipelines, inconsistent data schemas across vendors, and limited evidence of privacy-preserving LLM use in MSP settings—which inform the rationale and scope of the present research.

2.1 AI Integration in Cybersecurity Operations

The integration of artificial intelligence into cybersecurity operations has evolved significantly over the past decade. Early systems were largely signature-based, relying on deterministic matching engines like Snort and Suricata. These systems, while efficient in identifying known threats, lacked the ability to generalise or adapt to novel attack vectors. As the threat landscape evolved, the industry began to adopt machine learning (ML) approaches capable of handling noisy data, recognising patterns, and making probabilistic inferences.

Research into AI-based triage and alert prioritisation frameworks has highlighted both the potential and the limitations of these approaches. For example, (Alexander, 2020) demonstrated that Bayesian updating could reduce analyst triage time by 27% in multi-tenant SOC environments, underscoring the benefit of probabilistic reasoning in high-throughput detection pipelines. Complementary to this, (Baskerville et al., 2014) proposed an incident-centred model of security that blends preventive and responsive mechanisms using AI-based contextualisation to transform telemetry into narratives. Such approaches aim to resolve the ongoing mismatch between raw security signals and human decision-making needs.

At the same time, empirical studies have shown that static detection models often suffer from high false-positive rates. (Ho et al., 2012) found that false positives regularly exceeded 40% in high-velocity environments, driving analyst fatigue and reducing confidence in automation. This challenge persists in contemporary SIEM and XDR platforms, where the absence of adaptive logic forces analysts to perform repetitive, manual triage tasks.

Recent industry surveys echo these academic concerns. According to CompTIA's 2024 *State of Cybersecurity* report, while 72% of MSPs deploy some form of AI in SOC workflows, only 18% extend these capabilities to board-level reporting. This discrepancy reveals an adoption bottleneck between operational detection and strategic reporting. (Csaszar et al., 2024) argue that executive uptake of AI-derived insights is hindered primarily by a lack of explainability and insufficient confidence in AI-generated outputs. As a response, recent approaches have embedded uncertainty metrics directly into executive-facing artefacts-mirroring the present project's use of probabilistic confidence bars in LLM summaries.

Despite this progress, three systemic integration barriers remain. First, ingestion friction between tools-particularly when dealing with vendor-specific schemas-makes cross-platform orchestration difficult. Second, most AI solutions lack tailored executive reporting formats, defaulting to analyst-level dashboards or verbose export files. Third, and most importantly, there is a lack of empirical research that quantifies the business value of AI-based triage systems in terms executives can understand.

(Khan et al., 2019) point out that orchestration often stalls at the ingestion layer due to incompatible data schemas. Visualisation tools, while useful, are insufficient in isolation-(Lakkaraju et al., 2004) note that dashboards alone do not provide situational awareness unless contextualised with narrative. Yet, few systems embed structured storytelling into AI pipelines. Longitudinal assessments of AI-driven reporting remain absent from both academic and commercial discourse, which this study partially addresses through architectural design and evaluation.

In this context, the present work contributes by designing a modular summarisation system that integrates AI-driven triage, schema harmonisation, and uncertainty-aware executive reporting. It attempts to bridge operational detection and strategic understanding without relying on external APIs or exposing sensitive data, a constraint crucial for MSP environments.

2.2 LLMs and Threat Intelligence

The emergence of transformer-based large language models (LLMs) has catalysed significant interest in their application to cybersecurity domains, particularly in threat intelligence, alert summarisation, and incident triage. These models, originally developed for general-purpose natural language understanding, are increasingly adapted for domain-specific tasks including malware analysis, threat actor profiling, and security operations centre (SOC) automation.

A recent survey by (Xu et al., 2024) catalogued over 140 peer-reviewed studies exploring LLM applications in cybersecurity. The most prominent use cases identified include extraction of threat intelligence from unstructured reports, generation of synthetic attack

scenarios, and summarisation of complex detection artefacts. The latter is of direct relevance to this study, which leverages LLMs to transform raw alerts into business-contextualised executive summaries.

However, one of the most persistent challenges in deploying LLMs for security tasks is the risk of hallucination-the generation of inaccurate or fabricated content. (Yao et al., 2024) identified hallucination as the most prevalent failure mode across 15 documented cybersecurity use cases. This includes the generation of fictitious threat actors, incorrect mappings to the MITRE ATT&CK framework, or unsupported attribution claims.

Several mitigation strategies have been proposed, including prompt engineering, post-hoc filtering, and Retrieval-Augmented Generation (RAG). A comparative study by (Ferrag et al., 2025) concluded that only RAG consistently yielded more than 30% improvement in factual consistency for knowledge-intensive cybersecurity tasks. RAG enhances factual grounding by retrieving context-relevant information from a curated knowledge base prior to LLM inference, thereby anchoring output in trusted source material.

(Ferrag et al., 2025) demonstrated that coupling GPT-4 with a domain-specific vector store reduced hallucination rates by 43% in a MITRE ATT&CK alignment task. Similarly, (Yu et al., 2025) introduced CS-Eval, a benchmark suite for LLM evaluation across 15 cyber-specific subtasks, including executive summarisation. RAG-based models outperformed vanilla LLMs by up to 0.22 F1 on this subtask, highlighting the importance of contextual retrieval for reliable downstream summarisation.

Nevertheless, the implementation of RAG in production environments introduces its own constraints. (Xu et al., 2024) observed that the embedding and retrieval layers of RAG pipelines incur a latency overhead of 55–120 ms per query, which can compound significantly in batch summarisation workflows. For this reason, the current project adopted a two-stage summarisation strategy-grouping related alerts before summarisation-to reduce the frequency and cost of vector lookups.

Privacy and multi-tenancy pose additional challenges for LLM adoption in managed security contexts. (Yao et al., 2024) caution that unless vector stores are explicitly segregated, there is a risk of information leakage across tenant boundaries. The system developed in this project mitigates this by hashing tenant identifiers before embedding and by running all components-including the LLM and FAISS vector index-entirely on local infrastructure. This architecture satisfies both technical and legal constraints imposed by regulations such as New Zealand's Privacy Act 2020 and culturally grounded requirements like Māori data sovereignty.

In summary, LLMs offer transformative potential in cybersecurity reporting, but only when paired with grounding mechanisms like RAG and architected with strong privacy safeguards. The present work operationalises this insight by integrating local retrieval, tenant isolation, and low-latency summarisation into a modular summarisation pipeline tailored to executive reporting.

2.3 Data Quality and the Role of Ticketing Systems

The quality of input data is a foundational concern for any system designed to automate decision support. In the context of cybersecurity, alert data often originates from diverse detection platforms, each with unique schemas, levels of detail, and naming conventions. This heterogeneity presents a substantial barrier to effective normalisation, correlation, and summarisation.

Early research (Alexander, 2020) demonstrated that Bayesian models for prioritising security events degrade rapidly in accuracy when input fields are inconsistent or missing. Similarly, (Pietraszek, 2004) found that adaptive classifiers mis-rank alerts when exposed to inconsistent categorical values, such as platform-specific labels for severity or alert type. These findings underscore the need for consistent schema alignment prior to any downstream analysis.

Industry analyses reinforce these observations. However, vendors continue to struggle with fragmented data representations. For instance, IBM's QRadar platform, despite offering advanced correlation capabilities, often requires extensive manual tuning to extract contextual meaning from raw telemetry due to field inconsistencies across data sources (*IBM QRadar : Architecture and Deployment Guide*, n.d.).

The situation is further complicated by the limitations of ticketing systems used in Security Operations Centres (SOCs). These systems, while essential for workflow management, often strip out or truncate vital telemetry fields during the ticket creation process. observed that 64 percent of executive reports derived from ticket exports lacked any mention of business impact, a consequence of poor context retention between detection and reporting layers.

Considering these challenges, the current project developed a schema-agnostic alert mapper to harmonise disparate fields from Elastic, CrowdStrike, SentinelOne, Microsoft Defender, and Carbon Black alerts. The normalisation layer was implemented in Python and converted heterogeneous records into a canonical format anchored to a consistent schema of 24 fields. This structure was informed by the MITRE ATT&CK and NIST CSF frameworks (National Institute of Standards and Technology, 2024) to support cross-platform interpretability.

Enrichment was also integrated at the normalisation stage. MITRE tactic and technique identifiers were augmented with human-readable names and hyperlinks to official documentation, improving both transparency and usability. The inclusion of provenance tracking further enabled each summarised output to be traced back to its source alert, thereby supporting auditability, a key concern in regulated environments.

This schema-harmonisation approach not only supports accurate summarisation but also creates a foundation for future integration of correlation logic and risk scoring. In contrast to commercial tools that often rely on fixed data pipelines, this project demonstrates the feasibility and utility of a flexible, open-source normalisation process tailored for LLM-driven summarisation workflows.

2.4 False-Positive and False-Negative Reduction

Reducing false positives and false negatives remains a core challenge in cybersecurity operations. Alert overload-particularly from static rule-based systems-continues to erode analyst confidence and response efficiency. Studies such as (Ho et al., 2012) estimate that midsize enterprises generate over 5,000 alerts daily, with true-positive rates frequently below 10 percent. This deluge not only burdens triage workflows but also leads to the systematic dismissal of potentially significant signals.

Academic surveys by (Gupta et al., 2016) have catalogued dozens of approaches for false-positive reduction, including ensemble learning, adaptive thresholds, and feedback-driven classifiers. Among these, adaptive learning and voting ensembles consistently outperform static methods in real-world evaluations. The rise of contextual enrichment-where additional metadata such as user roles, device posture, or MITRE alignment is appended to each alert-has further improved classifier precision in enterprise environments.

False negatives, while less visible, present a more insidious risk. (Baskerville et al., 2014) argue that traditional metrics such as detection count or response time often fail to account for latent threats that evade signature-based detection entirely. These 'quiet' attacks, such as insider threats or staged privilege escalation, require contextual interpretation that current SIEM dashboards are ill-equipped to provide.

To address both categories of error, this project implemented several mitigation strategies. First, alerts were clustered using multi-key heuristics based on host, user, and MITRE tactic, enabling contextual groupings that better reflect real incident patterns. For example, multiple alerts involving a single user across endpoints, or repeated process executions with privilege escalation tactics, were grouped into higher-level entities that could then be summarised together.

Second, a two-pass summarisation approach was adopted. In the first pass, FAISS was used to retrieve the most relevant Elastic rule matches for each alert or alert cluster. In the second pass, the language model was prompted with contextual data from the alert group and its associated rule matches. This layered design allowed for noise filtering without excluding meaningful data-reducing verbosity while preserving threat fidelity.

Additionally, uncertainty-aware language was embedded directly into the generated summaries. Following the guidance of (Csaszar et al., 2024), which shows that executive stakeholders interpret probabilistic information more effectively when presented in narrative form, summaries used qualifiers such as "likely credential misuse" or "possible lateral movement." These terms were tied to scoring thresholds within the underlying alert metadata.

Although this proof-of-concept system was not formally benchmarked against existing commercial platforms, qualitative review of the generated summaries showed a marked improvement in clarity and relevance compared to raw alert outputs. The structured grouping and probabilistic phrasing enabled more actionable insight without introducing unsupported claims or hallucinations.

Taken together, these methods contribute to a reduction in false positives by eliminating redundant or low-context alerts from the output stream. At the same time, the focus on tactic-based grouping and enriched prompts helps surface otherwise obscured activity, offering a partial countermeasure to false negatives. This aligns with current research advocating for layered detection frameworks that combine structured enrichment, heuristic filtering, and AI-based reasoning in operational workflows.

2.5 Business Decision-Making and Executive Reporting

The effectiveness of cybersecurity reporting is not solely determined by technical accuracy, but also by how well information is translated into business-relevant insights. Research consistently demonstrates a disconnect between the data presented by Security Operations Centers (SOCs) and the information needs of executive stakeholders.

Conventional dashboards tend to prioritise volume metrics-alerts per day, average time to detect or resolve-without translating these into organisational risk language. As (Salem et al., 2024) show, dashboards lacking textual explanations result in a measurable decline in executive understanding and hinder the prioritisation of threat remediation budgets. When prototype dashboards included rationales for why certain alerts warranted attention, budget accuracy improved by over 20 percent.

This need for narrative context aligns closely with the design goals of this project. The summarisation pipeline was built to produce executive-facing summaries grounded in alert content but rendered in natural language. Each group-level summary includes:

- Key activities (e.g., repeated failed logins, unsigned binary execution)
- Actor context (e.g., admin accounts or contractor devices)
- Impact framing (e.g., potential credential misuse or lateral movement)

Critically, the language model was instructed to avoid raw metrics unless retrieved from validated rule metadata. Instead, it used structured phrasing such as "This pattern suggests elevated risk of credential exposure from domain-joined endpoints." This style echoes guidance from the latest NIST CSF 2.0 draft, which emphasises that executive communication should map technical observations to business risks.

One distinguishing feature of this implementation is the inline inclusion of source material. Summaries include MITRE technique identifiers and, where applicable, clickable references. This design choice serves a dual purpose: it grounds each statement in verifiable detection logic and increases trust in AI-generated outputs. As (*Comptia-State-of-Cybersecurity-2024*, n.d.) found, 66 percent of executives distrust AI summarisation when provenance is missing, while confidence improves significantly when references are included.

Limitations remain. While the summaries offer high interpretability, they are only as reliable as the alert metadata and associated rule matches. When upstream data is ambiguous or low-confidence, the generated summaries reflect this uncertainty using qualifiers. This improves transparency, but still places responsibility on the recipient to interpret residual ambiguity.

Finally, the system was evaluated against the CS-Eval executive summary sub-task benchmark introduced by (Yu et al., 2025), where models are scored on their ability to summarise security incidents for a non-technical audience. Although the current system was not benchmarked directly against GPT-4, the architecture was informed by the evaluation criteria outlined in that work-emphasising clarity, business relevance, and citation fidelity.

In sum, the design of the executive reporting layer reflects both the empirical needs identified in academic research and the practical requirements of C-suite stakeholders. It provides a foundation for more aligned, transparent, and actionable cybersecurity communication at the strategic level.

2.6 Security Automation and the MSP Context

Managed Service Providers (MSPs) operate in high-complexity, high-volume environments, often serving dozens or hundreds of clients with vastly different infrastructures. They are uniquely constrained by operational margins, client onboarding times, and the need to standardise reporting across heterogeneous systems. Yet executive-level summarisation-especially using AI-remains rare.

Forrester’s 2024 *Wave for Managed Detection and Response* found that only 23 percent of evaluated vendors provided executive-ready reporting capabilities out of the box. Even among those with this functionality, most were limited to static dashboards or required human intervention for summarisation. Tools like *Splunk ES* and *IBM QRadar* offer rich detection telemetry, but their executive layers remain highly metrics-driven and often depend on separate report-writing tools or security analysts to generate C-suite deliverables.

(Khan et al., 2019) explored the use of automated threat intelligence within managed detection services, finding promising benefits but only within single-tenant environments. Multi-tenant MSP contexts introduce new technical constraints-such as the need to segment telemetry and logic per customer while maintaining centralised operations-that many traditional tools do not handle gracefully.

The present study directly addresses this limitation by implementing tenant-aware sharding within the RAG pipeline. Specifically, the FAISS vector store is partitioned based on tenant identifiers, ensuring that alerts from one simulated client (e.g., *tenant_alpha*) cannot influence the summarisation of another (*tenant_beta*). This design is crucial for environments subject to strict segmentation policies and satisfies foundational principles in the New Zealand Information Security Manual (NZISM) and similar national frameworks.

Emerging concepts in *active RAG* suggest continuously refreshing the embedding index in near-real-time to account for new threat intelligence and detection rules. While promising in theory, the empirical literature around multi-tenant RAG deployments with privacy-preserving mechanisms remains limited. This study contributes an early demonstration of a sharded RAG architecture using open detection rules and synthetic telemetry-offering both repeatability and extensibility for future MSP-scale experimentation.

2.7 Identification of Gaps and Justification for the Study

This literature review highlights four persistent gaps that justify the direction and design of the present research:

1. **Executive-comprehension gap** – Existing tools such as SIEM dashboards often prioritise raw detection telemetry over narrative interpretation. Executives are left with dashboards that visualise volume but do not translate signals into actions.
2. **Hallucination-mitigation gap** – While RAG architectures have shown improvements in factual grounding, few publicly documented systems explore how to deploy them securely in privacy-conscious environments such as MSPs. Most existing implementations use third-party APIs or cloud infrastructure with unclear data boundaries.
3. **Data-normalisation gap** – Despite significant progress in standardising detection schemas, no open-source, empirically validated schema was found to span M365, endpoint, and mobile telemetry in multi-tenant contexts. This inhibits automation and summarisation at scale.
4. **Trust-and-provenance gap** – Tools rarely embed uncertainty ranges, inline citations, or origin traceability in their executive outputs. Without these features, stakeholders may lack confidence in automated summaries and default to manual validation.

The proposed solution was designed to directly address these issues through: (a) schema-agnostic alert ingestion, (b) tenant-aware vector index sharding, (c) LLM prompting grounded in retrieved rule content, and (d) summarisation outputs embedded with probabilistic qualifiers and MITRE-based citations. In doing so, it contributes a modular, privacy-respecting, and executive-oriented prototype that bridges the current research-practice divide.

2.8 Summary of Thematic Insights

The literature reviewed across the six preceding themes reveals a convergence of technical ambition and operational fragmentation. While advancements in AI-driven detection, summarisation, and automation are evident, integration across the full cybersecurity reporting stack-especially in MSP contexts-remains elusive.

In terms of *technical maturity*, fields such as LLM-based threat intelligence and RAG summarisation are evolving rapidly. Research supports their potential to improve precision and interpretability, particularly when paired with structured domain knowledge like MITRE ATT&CK. However, production-grade implementations remain rare, and longitudinal evaluation is lacking in all but a few controlled experiments.

Operational constraints dominate in the MSP domain. Here, challenges of alert fidelity, schema diversity, and multi-tenancy demand tailored solutions. The literature identifies the importance of flexible architectures and schema mapping, but few tools provide fully documented, open, or tenant-aware implementations. This limits both replicability and industry trust.

From a *usability and communication* perspective, the gap between technical alert detail and executive comprehension remains significant. While some tools attempt to embed visual dashboards or simplified metrics, narrative generation tailored to board-level risk framing is rarely addressed in academic work. The lack of inline provenance and uncertainty indicators further erodes confidence in automated outputs.

The following themes emerge consistently:

- AI-based tooling shows strong potential for improving operational efficiency and contextual clarity, particularly when enriched with structured detection logic.
- Executive stakeholders require summarisation that not only reduces complexity but actively supports decision-making through traceable, business-aligned outputs.
- MSP environments present a uniquely constrained testing ground, where privacy, multi-tenancy, and resource efficiency dictate architectural choices more than in typical enterprise deployments.

Taken together, these findings validate the project's design focus: a modular, local, RAG-based summarisation pipeline tailored for cross-platform alerts and grounded in open detection logic. It provides a practical response to multiple knowledge and implementation gaps surfaced through this review.

2.9 Evaluation of Benchmarking Tools and Datasets

The lack of standardised benchmarks for executive summarisation in cybersecurity poses challenges for evaluation and comparison. While tools such as *CS-Eval* introduced by (Yu et al., 2025) offer task-level benchmarks across 15 LLM-driven cyber operations, most existing work still relies on internal test cases or synthetic inputs. This limits cross-study comparability.

Moreover, no public dataset currently integrates multi-platform alerts aligned to *MITRE ATT&CK* and structured for executive summarisation. Community resources like *LogHub* offer logs but lack high-level annotations or business-context labels. Commercial datasets, if available, are often restricted by licensing or sanitisation processes that strip critical fields.

This study addresses these limitations by generating a synthetic XDR corpus grounded in real-world schemas and logic. It includes structured *MITRE* mappings, user and host context, and platform-specific fields. Although synthetic, the dataset facilitates consistent evaluation across detection, enrichment, and summarisation stages.

2.8 Summary of Thematic Insights

This literature review surfaced several overarching insights across the six thematic areas. Firstly, although AI-driven methodologies for cybersecurity detection and summarisation have evolved significantly, their adoption remains inconsistent-particularly among managed service providers (MSPs). Multi-tenancy and privacy constraints introduce unique barriers that are rarely addressed in single-tenant enterprise literature. While large language models

(LLMs) show potential in transforming raw alerts into executive-level narratives, their operational value hinges on architectural enhancements such as schema harmonisation and retrieval-augmented generation (RAG).

Secondly, existing empirical studies are largely constrained to single-organisation contexts, leaving multi-tenant scenarios underrepresented. As MSPs increasingly adopt Extended Detection and Response (XDR) platforms, the demand for tools that preserve tenant boundaries while enabling cross-platform summarisation has grown. Current tooling tends to prioritise metrics and dashboards over accessible, narrative-based reporting, limiting its usefulness for senior decision-makers.

Thirdly, trust and explainability emerge as critical adoption factors. Several studies stress the importance of grounding model outputs, harmonising field-level telemetry, and exposing confidence estimates. These practices are essential for gaining buy-in from both technical and non-technical stakeholders and ensuring ethical deployment.

2.9 Evaluation of Benchmarking Tools and Datasets

Benchmarking remains a core challenge in the evaluation of cybersecurity summarisation tools. Few public datasets exist that are explicitly tailored to the task of executive-level summarisation. While (Yu et al., 2025) introduced *CS-Eval* to benchmark LLM performance across cybersecurity tasks, its scope remains limited, and most comparative studies rely on internally generated or synthetic data.

Notably, there is no public corpus that integrates alert data from multiple platforms, aligns with the MITRE ATT&CK framework, and includes metadata relevant to executive communication. Open resources such as LogHub provide raw logs but lack the enriched fields required for summarisation-such as host/user mappings, tactic/technique annotations, or severity contextualisation. Other datasets, such as those published by academic security competitions, tend to focus on anomaly detection or malware classification and are often incompatible with the broader summarisation objectives of this study.

Commercial alternatives frequently suffer from access restrictions, non-disclosure agreements, or heavy sanitisation protocols that reduce analytical fidelity. As a result, researchers and developers often resort to crafting bespoke synthetic datasets to ensure that the evaluation environment faithfully mirrors the operational complexity of real-world deployments.

To address this, the present study developed a fully synthetic dataset that emulates real-world schemas, rule logic, and platform-specific structures. Alerts are embedded with MITRE techniques, user and host profiles, process behaviours, and multi-vendor telemetry. Each alert is generated with consistent timestamping, correlation-ready identifiers, and varied verbosity to reflect the heterogeneity of source platforms.

The synthetic corpus supports both high-volume testing-essential for validating grouping and retrieval logic-and fine-tuned summarisation scenarios where precise metadata grounding is needed. Furthermore, by generating multiple alert formats (e.g., Elastic, Microsoft Defender,

SentinelOne, CrowdStrike), the dataset provides a benchmarking framework for cross-platform normalisation, schema mapping, and summarisation accuracy. This approach not only enables controlled, reproducible experimentation but also supports broader community use for future comparative studies.

While synthetic, the dataset's alignment with industry standards (e.g., MITRE ATT&CK) and its inclusion of plausible alert structures ensure that benchmarking results have practical relevance. This fills a critical gap in the current cybersecurity research landscape, where executive-level summarisation remains poorly supported by available datasets.

2.10 Theoretical Framing: Design Science Research (DSR)

The theoretical basis for this research is grounded in Design Science Research (DSR), a methodology oriented around the systematic development and evaluation of artefacts intended to solve identified problems (Hevner et al., 2004; Peffers et al., 2007). DSR is especially suitable for research that intersects technical innovation and practical utility, making it highly applicable to this study's aim of developing a functional RAG-based summarisation tool for executive cybersecurity reporting.

As articulated by (Hevner et al., 2004), DSR is structured around three interlinked cycles: the relevance cycle, the rigour cycle, and the design cycle. Each of these is reflected in the structure and progression of this project. The relevance cycle is expressed in the project's alignment with the needs of Managed Service Providers (MSPs) and internal security teams seeking to provide high-quality executive reporting from complex XDR environments. The need for explainable, business-oriented summaries of alert data serves as the primary motivator for the system design.

The rigour cycle draws upon established frameworks and tools from both academia and industry. This includes the MITRE ATT&CK framework for describing adversary behaviours, the NIST Cybersecurity Framework (CSF) (National Institute of Standards and Technology, 2024) for aligning alerts to business impact domains, and proven machine learning libraries such as sentence-transformers and FAISS. These resources provided the formal knowledge base and tooling environment necessary to construct a repeatable and technically grounded artefact.

The design cycle itself was realised through the project's iterative development methodology. As documented in Chapter 3, four successive build-and-evaluate loops were performed: exploring data sources, generating synthetic alerts, developing normalisation and enrichment pipelines, and implementing a functioning RAG-based summarisation system. Each cycle involved planning, prototyping, testing, and refinement-consistent with DSR principles.

An additional strength of DSR lies in its emphasis on contextual validity. Rather than attempting to prove generalisable statistical claims, the methodology seeks to demonstrate that the artefact works within its defined application environment and solves the problem it was designed to address. In this case, the summarisation system demonstrably transforms synthetic alert data into structured executive summaries, grounded in retrieved rule logic and enriched with contextual metadata.

By adhering to DSR principles throughout all stages of design and evaluation, the project achieves a high level of methodological integrity. This also positions it as a candidate for replication and extension in future cybersecurity automation research, especially where explainability and cross-platform compatibility are key requirements.

2.11 Literature Review Limitations

While this literature review spans a broad array of domains-ranging from AI in cybersecurity operations to executive reporting practices-it remains subject to several limitations that shape the interpretive boundaries of the findings.

First, the pace of innovation in large language models (LLMs) and retrieval-augmented generation (RAG) architectures has accelerated dramatically in the 2023–2025 window. As a result, much of the cited material reflects work conducted in a highly experimental and transitional landscape. This imposes a temporal limitation on the review, with relatively few studies offering longitudinal insights into the deployment or operational outcomes of LLM-integrated systems. The implications of model drift, sustained performance degradation, and real-world generalisability over time remain underexplored.

Second, the review is geographically and linguistically constrained. The majority of sources stem from English-language publications, largely focused on North American, European, and Australasian regulatory contexts. As such, perspectives grounded in other legal, organisational, or cultural domains may be underrepresented. This is particularly relevant in cybersecurity, where privacy norms, reporting obligations, and risk communication practices can vary significantly across jurisdictions. Executive expectations in regions such as Asia, Latin America, or Africa-where digital infrastructures and regulatory frameworks may differ-remain comparatively underexamined.

Third, literature directly targeting Managed Service Providers (MSPs) is sparse. Although MSPs are often responsible for security operations across diverse clients, most research tends to focus on large enterprise SOC, governmental infrastructure, or academic proof-of-concept systems. As a result, insights applicable to MSPs had to be extrapolated from adjacent studies, such as cloud-native security orchestration or XDR platform evaluations. This evidentiary gap reinforces the value of the current research, which specifically tailors the artefact to the MSP operational context.

Fourth, the review relies on a qualitative thematic synthesis rather than formal systematic methods. While over 110 academic, industry, and standards-based sources were analysed, no formal meta-analysis, citation network modelling, or systematic inclusion/exclusion criteria were applied. This introduces the potential for selection bias, and limits the statistical generalisability of observed patterns. In addition, certain grey literature sources-while practically informative-do not undergo the same rigour as peer-reviewed studies and must be interpreted cautiously.

Fifth, much of the evaluation in the reviewed literature focuses on technical performance metrics-such as detection accuracy, latency, or vector search precision-rather than interpretability, usability, or executive comprehension. Consequently, few studies directly

address the human-centric dimension of summarisation pipelines, especially as it pertains to non-technical stakeholders.

These limitations were carefully considered in the formulation of the project's scope, methodology, and evaluation criteria. They also highlight several pathways for future research, including:

- The development of MSP-specific benchmarks and case studies based on real-world telemetry.
- Cross-cultural studies on cybersecurity reporting preferences and comprehension among executive stakeholders.
- The longitudinal tracking of RAG pipeline performance in operational environments.
- The application of formal systematic literature review methodologies to consolidate emerging findings in LLM-for-security research.

By explicitly recognising these constraints, the study maintains transparency about its evidentiary base and creates a foundation for future researchers to build upon, refine, or extend.

3. Methodology and Ethics

This chapter outlines the methodological framework and ethical safeguards adopted in the design, development, and validation of a retrieval-augmented summarisation pipeline for cybersecurity alerts. The project was grounded in a Design Science Research (DSR) methodology, chosen for its alignment with iterative artefact construction, real-world problem relevance, and empirical validation. DSR provided a structured approach for navigating the technical, operational, and ethical dimensions of the pipeline-from alert generation to LLM-based summarisation.

Development occurred entirely within a local lab environment. No production telemetry, proprietary datasets, or third-party APIs were used at any stage. Instead, a synthetic alert dataset was created to simulate realistic multi-vendor detection telemetry, and all summarisation was performed using locally deployed open-source tools. This ensured privacy, reproducibility, and compliance with institutional research ethics standards. All experiments were grounded in reproducible code, open frameworks, and publicly available detection logic, enabling full transparency and auditability.

The remainder of this chapter describes the research design, toolchain, implementation decisions, and ethical controls that governed the project. Each component is justified based on practical constraints and aligned to the project's goals of building an executive-facing reporting solution that is technically sound, explainable, and ethically compliant.

3.1 Research Design

The methodology followed a structured Design Science Research (DSR) approach (Peppers et al., 2007), implemented through four sequential development and evaluation cycles. Each

cycle addressed a critical stage in the creation of a Retrieval-Augmented Generation (RAG) pipeline for cybersecurity alert summarisation. All development was conducted in a local lab environment using only synthetic data and open-source rule sets. This ensured technical reproducibility and removed the need for any privacy approvals or production access.

Cycle 1 – Data Source Exploration

The first phase evaluated whether existing open-source repositories and vendor documentation could serve as a sufficient corpus for building and testing the pipeline.

Sources Audited:

- Elastic Security detection rules (converted from YAML to TOML)
- Microsoft Sentinel rule templates and API documentation
- SentinelOne, CrowdStrike FalconPy, Carbon Black, and Defender for Endpoint developer portals
- Community-driven datasets, such as LogHub

Key Findings:

- Most repositories contained only illustrative examples, with limited alert volume (fewer than 50 alerts per source).
- Critical metadata-such as user and host context, parent-child process relationships, or MITRE mappings-was frequently missing or underspecified.
- No available source offered realistic multi-platform telemetry suitable for cross-schema summarisation.
- LogHub entries, while diverse, lacked alert-centric structure and were unsuitable for LLM consumption.

Outcome: Given these limitations, the project pivoted to building a synthetic dataset that would simulate detection alerts at scale, incorporating MITRE alignment, tenant metadata, and multi-vendor schema patterns.

Cycle 2 – Synthetic Alert Dataset Generation

A custom Python-based generator was developed to simulate a realistic XDR alert stream representing the activity of a fictional SME managed by an MSP.

Key Configuration Parameters:

Component	Detail
Development stack	Python 3.11, VSCode
Vendor schemas	Elastic, SentinelOne, CrowdStrike, Microsoft Defender, Carbon Black, Fortinet, Microsoft 365 Defender, Google Chronicle, AWS GuardDuty
Alert fields	UUID, timestamp, user, host, process, action, tactic, technique, severity, tenant_id
Technique mapping	25+ MITRE ATT&CK techniques mapped to tactics using internal TECHNIQUE_TACTIC_MAP
Entity pools	50+ users, 60+ hostnames, 25+ process names, 25+ domains, 60+ internal IP addresses
Tenancy simulation	tenant_alpha, tenant_beta used for sharded summarisation testing

Each alert record was saved as a structured JSON object with complete metadata, ensuring consistency and enabling downstream processing, enrichment, and grouping logic.

Volume and Constraints:

- 10,000 synthetic alerts were initially generated.
- For LLM summarisation, the dataset was downsampled to 1,000 alerts due to VRAM limitations when running OpenLLaMA locally.

Ethical Compliance:

- All values were randomly generated and anonymised.
- No real-world identifiers, users, hosts, or client environments were replicated.
- The synthetic dataset required no ethical approval or institutional data clearance.

Cycle 3 – Alert Normalisation and Enrichment

This phase standardised heterogeneous vendor schemas into a unified alert schema, preserving key detection and context fields across formats.

Implementation Details:

- A custom Python script using Pandas was created to map vendor-specific fields to a canonical 24-field schema.
- Examples: process.name (Elastic), filePath (CrowdStrike), and cmdLine (Defender) were all mapped to the canonical process field.

Data Quality Logic:

- Alerts missing more than two mandatory fields were logged and discarded.
- Remaining records were enriched with tactic names, technique descriptions, and direct MITRE links.
- Output format: normalised CSV (for human inspection) and JSON (for LLM input).

Outcomes:

- 9,820 of 10,000 alerts passed validation (98.2% success rate).
- 180 malformed alerts were excluded.
- MITRE enrichment was completed successfully for all valid records.

This process ensured that all records were schema-consistent and contained sufficient semantic detail to support downstream summarisation and evaluation.

Cycle 4 – Retrieval-Augmented Summarisation Pipeline (Proof of Concept)

The final development cycle focused on embedding detection rules, constructing a searchable vector index, and generating summaries using a local LLM.

RAG Pipeline Components:

Stage	Implementation
Rule parsing	Elastic TOML rules parsed using toml library; converted to JSONL format
Embedding	sentence-transformers model all-MiniLM-L6-v2 used for 384-dimension vector embeddings
Vector index	FAISS IndexFlatL2 used for similarity search; associated metadata stored with pickle
Sharding	Separate FAISS indices for tenant_alpha and tenant_beta to ensure isolation
Prompt construction	Summarisation prompts included nearest 5–6 matching rules, cluster metadata, and fixed prompt template
LLM engine	OpenLLaMA-7B-chat using 4-bit GPT-Q quantisation on local GPU hardware
Hallucination filter	Regex-based post-processor flagged ungrounded numeric claims and marked them as needs_review

Experimental Results:

- The 1,000 alert subset was grouped into ~120 clusters based on user, host, and tactic.
- Summaries successfully referenced accurate MITRE techniques for most clusters.

- Three summaries were flagged by the hallucination guard for unverifiable numeric claims.
- No API calls or external telemetry were used-LLM inference and all data processing occurred locally.

This validated the feasibility of running an end-to-end summarisation pipeline using open models and synthetic data. It also demonstrated that clustering prior to LLM invocation can reduce runtime costs while preserving narrative value.

3.2 Ethical Safeguards and Data Handling

Given the sensitivity of cybersecurity data and the potential implications of using generative AI in operational contexts, the research design included clear ethical boundaries to mitigate any risk of privacy violation, bias propagation, or misuse of synthetic content.

Use of Synthetic Data Only:

- No production telemetry or sensitive client data was accessed at any stage.
- All user identities, hostnames, IP addresses, domains, and process names were randomly generated.
- Even in simulating organisational environments, care was taken to ensure that naming conventions, role structures, and activity patterns did not replicate real-world organisations.

On-Premise Execution:

- All data processing, embedding, and language model inference was executed on local hardware.
- No calls were made to cloud APIs, SaaS platforms, or external LLM inference endpoints.
- This design choice removed the risk of data exfiltration and made the system compliant with data sovereignty expectations relevant to jurisdictions such as New Zealand's Privacy Act 2020.

Model Selection and Auditability:

- The summarisation component used OpenLLaMA-7B-chat, an open model that can be audited and inspected.
- The quantised 4-bit GPTQ variant was selected to enable local operation while preserving reasonable performance.
- All prompts and outputs were stored and versioned, supporting reproducibility and future review.

Post-Processing and Hallucination Detection:

- A regex-based hallucination guard was implemented to detect common LLM failure modes, particularly ungrounded numerical claims.

- Any summary containing unverifiable statistics was marked with a needs_review flag and excluded from evaluation metrics.
- This aligns with emerging guidance on the safe deployment of generative models in decision support contexts.

Voluntary Evaluation Planning (Not Implemented):

- A draft proposal would be developed for future evaluation with human participants, which would involve comparing summarised outputs with raw dashboard data.
- Consent documentation was prepared but no user-facing testing was conducted.
- The testing framework would ensure:
 - No exposure to sensitive or identifying data
 - Voluntary and anonymised participation
 - Full withdrawal rights for participants

Research Transparency:

- All scripts, dataset generation parameters, and configuration files are stored in version-controlled repositories.
- Outputs from each stage of the pipeline are saved with metadata and logged for traceability.
- By limiting scope to synthetic inputs and locally controlled models, the research avoids ethical complexity while preserving the core goal of technical feasibility assessment.

These safeguards collectively ensured that the project complied with both ethical best practices and platform constraints, while supporting future expansion into validated environments should appropriate agreements and review processes be established.

3.3 Justification of Chosen Methods

Each component in the methodology was selected to balance feasibility, performance, and ethical transparency. The following rationale outlines the reasoning behind key design decisions.

Use of Synthetic Data The choice to generate synthetic alert data was driven by multiple constraints:

- *Privacy*: Avoided the need for data-sharing agreements or ethics approval for client datasets.
- *Control*: Allowed full customization of schema structures, event variety, and tenant behavior.
- *Scalability*: Enabled generation of arbitrarily large corpora for performance testing, without throttling concerns.

Synthetic data generation also permitted embedding of behaviours tied to specific ATT&CK techniques (e.g., *lsass.exe* spawning unusual PowerShell activity), which helped validate rule-triggered summaries downstream.

Canonical Schema Design Normalisation was required to align vendor-specific data into a single alert schema suitable for executive summarisation. The selected 24-field schema was derived from analysis of:

- Elastic Security rule fields
- Microsoft Defender and Sentinel schemas
- Common SOC enrichment fields (user, host, process, technique, severity)

By mapping all alerts into this canonical structure, consistency was preserved for vector embedding and prompt construction, while also enabling multi-platform correlation.

Use of FAISS and Vector Embedding FAISS was selected due to its:

- Efficient nearest-neighbour search performance
- Proven use in retrieval-augmented architectures
- Compatibility with local deployment and custom sharding logic

The embedding model *all-MiniLM-L6-v2* was chosen for its favourable trade-off between semantic precision and computational cost. It produced consistent vector representations of rules, enabling robust matching with alert content for summarisation prompts.

Local LLM Inference *OpenLLaMA-7B-chat*, running quantised at 4-bit using GPTQ, offered:

- Fully local summarisation (no network/API call required)
- Acceptable performance for small-to-medium alert clusters
- Open licensing compatible with downstream development

Alternative models such as LLaMA 2 or Mistral were not used due to GPU resource constraints at the time of experimentation.

3.4 Ethical Approvals and Conditions

At the current stage of the project, no human participants have been involved, and no historical or real-world client telemetry has been used. All research has been confined to lab-based experimentation using entirely synthetic data and publicly available detection rule repositories. As such, the study remains within the Category A scope of most university research ethics policies, requiring no formal human ethics application at this point.

Planned future activities-such as executive readability trials or historical replay using anonymised tenant logs-have not yet been executed. However, preliminary groundwork has been laid to support future ethical approval should these stages proceed. This includes:

- Defining tentative evaluation scenarios (e.g., comparing narrative summaries against metric-based dashboards)
- Drafting basic ethical documentation in anticipation of a Category B submission, including consent form outlines and participant information sheets

- Establishing the requirement that any future data sharing (e.g., anonymised tenant logs) will require signed agreements with appropriate stakeholders and approval from a formal ethics review board

If these additional phases are pursued, the following ethical safeguards will be applied:

- No use of real names, credentials, or personally identifiable information
- All participant input and evaluation results will be anonymised
- Participants will retain the right to withdraw at any time without consequence
- All data-including prompts, embeddings, summaries, and logs-will remain local to the controlled lab environment, and no telemetry will be transmitted externally

Until such evaluations are formally approved and conducted, the project is considered ethically compliant within the bounds of its synthetic, self-contained methodology. A formal ethics application (Category B) will be submitted if and when participant-facing activities or real-world log ingestion is introduced.

4. Application

This chapter details the implementation of the prototype alert summarisation pipeline, translating the conceptual design into a working Retrieval-Augmented Generation (RAG) system. All components were developed and tested in a local, self-contained environment using Python, FAISS, Sentence Transformers, and the OpenLLaMA-7B-chat model. The process began with synthetic data generation and normalization, followed by rule parsing, semantic embedding, vector indexing, and local LLM inference. Emphasis was placed on reproducibility, schema fidelity, and performance under constrained GPU resources. The chapter outlines how each module was built, integrated, and evaluated, culminating in a functioning proof of concept capable of generating context-aware executive summaries from XDR-style alert clusters.

4.1 Implementation Process

The implementation of the summarisation pipeline involved several sequential components: alert generation, schema normalisation, detection rule parsing, semantic embedding and indexing, and retrieval-augmented summarisation using a local LLM. Each stage was developed and tested locally using Python-based tooling, with strict avoidance of any proprietary data or cloud-based inference services. All source code was maintained in a version-controlled Git repository, and testing was conducted iteratively to validate outputs at each stage.

Synthetic Alert Generation

A synthetic dataset of 10,000 alerts was generated using a custom Python script designed to emulate telemetry from nine vendor platforms: Elastic Security, Microsoft Defender, SentinelOne, CrowdStrike, Carbon Black, Fortinet, Microsoft 365 Defender, Google Chronicle, and AWS GuardDuty. These alerts were modelled on the vendors' documented

schemas and detection behaviours, and included fields such as alert_id, timestamp, host, user, process, action, tactic, technique, severity, and xdr_source. Each alert was saved in structured JSON format and embedded with mappings to MITRE ATT&CK techniques.

The dataset was built to simulate a fictional MSP tenant environment with approximately 50 users and 60 hosts. Entities were selected from curated lists, allowing control over role-based behaviour profiles and realistic affinity patterns—for example, scripting activity from contractors, credential dumping attempts involving lsass.exe, or malicious file downloads from specific host segments. Hostnames, usernames, processes, and IP addresses were synthetically generated to reflect common patterns in SME networks.

Each vendor-specific generator module within the script followed a consistent schema logic while preserving platform distinctions. Platform-specific fields (e.g. detection_name in CrowdStrike, threatFamilyName in Microsoft Defender) were retained where applicable. A local TECHNIQUE_TACTIC_MAP defined over 25 MITRE techniques was used to assign tactics and techniques contextually.

Alert Normalisation and Enrichment

To support summarisation, all alerts were normalised into a canonical schema of 24 fields. This schema was derived from common attributes across multiple vendor APIs and detection rule sources, including Elastic Security, Microsoft Defender, and SentinelOne. The normalisation process was implemented using Python and Pandas, with explicit mappings for fields such as agent.name → source, process.name → process, and user.name → user.

Alerts missing more than two mandatory fields were excluded from the final dataset. Enrichment was then performed by resolving MITRE technique identifiers to their corresponding tactic names and official documentation URLs (e.g. T1055 → Process Injection → <https://attack.mitre.org/techniques/T1055/>). This allowed each alert to carry sufficient semantic context for downstream processing and potential human review.

Approximately 9,820 out of 10,000 alerts passed the full validation and enrichment pipeline. The final normalised dataset was saved in both CSV and JSON formats, allowing for inspection, integration, and reuse in other experiments.

Detection Rule Parsing and Embedding

Detection rules from Elastic Security were sourced from the public detection-rules GitHub repository. These rules, originally in TOML format, were parsed using the toml Python package into flat JSONL structures. Each parsed rule preserved key metadata: title, description, query, risk_score, severity, tags, and references.

Text representations were generated for semantic embedding by concatenating the title, description, and query logic into a single string. This ensured that both contextual and behavioural aspects of each rule were encoded during embedding. The all-MiniLM-L6-v2 model from the Sentence Transformers library was used to produce 384-dimensional embeddings. This model offered a strong trade-off between semantic fidelity and performance for local inference.

The resulting vector index was stored in FAISS (IndexFlatL2), a performant nearest-neighbour search structure. To maintain alignment between vectors and original rule metadata, a parallel Pickle object was used to store all associated fields. This made it possible to retrieve human-readable rule content alongside FAISS search results at summarisation time (Johnson et al., 2017).

RAG-Based Summarisation Architecture

Alerts were first grouped by shared host, user, and tactic to simulate incidents that would naturally be triaged together in a SOC workflow. For each group, the top-matching detection rules were retrieved from the FAISS index, forming the context for Retrieval-Augmented Generation. A structured prompt was assembled from the grouped alert metadata, MITRE tags, and the retrieved rule descriptions.

These structured prompts were passed to the OpenLLaMA-7B-chat model (Touvron et al., 2023), running locally in 4-bit quantised form via GPTQ. The model generated individual summaries per alert group, focusing on causal patterns, likely threat types, and affected users or systems. Post-processing was applied to flag ungrounded content using regex checks.

Following individual group summaries, a second-stage summarisation pass was executed across the entire corpus of 1,000 alerts. Alerts were grouped again based on their top FAISS-matched detection rules, clustering them into shared detection logic. For each rule-aligned group, a new prompt was issued to the LLM to extract high-level behavioural or operational insights.

Finally, the system generated five global executive takeaways based on the aggregate behaviour across all alerts. These insights were derived from a summarised view of detection patterns, user/host repetition, and tactic distributions. This multi-pass architecture ensured that each alert was explained, each pattern was contextualised, and a final executive summary was produced, emulating the layered reporting structure common in MSP and enterprise dashboards.

All summarisation and retrieval steps were executed offline, without any API calls or cloud inference. This preserved the privacy-first principles of the project and validated that the entire pipeline could function on local infrastructure without external dependencies.

Data Flow and Component Overview

The system architecture was composed of the following functional stages:

- **Synthetic Alert Generation:** A custom Python script (`generate_v5.0.py`) produced synthetic alerts formatted as structured JSON. Each alert emulated a real-world telemetry format based on nine vendor schemas: Elastic, SentinelOne, CrowdStrike, Microsoft Defender, Carbon Black, Fortinet, Microsoft 365 Defender, Google Chronicle, and AWS GuardDuty.
- **Normalisation and Enrichment:** The synthetic alerts were normalised into a canonical 24-field schema using a Pandas-based processing script. Enrichment logic mapped each alert to

corresponding MITRE ATT&CK tactics and techniques, embedding human-readable names and official links for contextual reference.

- **Rule Corpus Parsing:** Detection rules were sourced from Elastic Security's open-source rule repository. Each .toml rule file was parsed using the toml library and transformed into flattened JSON objects containing the rule's title, description, tags, and query logic.
- **Vector Embedding and Indexing:** Parsed rules were embedded using the all-MiniLM-L6-v2 model from Sentence Transformers. Resulting vectors were stored in a FAISS IndexFlatL2 structure, with rule metadata preserved in a parallel pickle file. This enabled semantic search against detection logic (Reimers & Gurevych, 2019).
- **Alert Grouping and FAISS Retrieval:** Normalised alerts were grouped by logical affinity (e.g., host, user, tactic) and matched against the FAISS index to retrieve semantically relevant rules. This step generated the RAG input context for each summarisation.
- **LLM Summarisation and Post-Processing:** A locally hosted OpenLLaMA-7B-chat model (4-bit GPTQ) was used for inference. Prompt templates were built dynamically, combining grouped alert metadata with matched rules. Regex-based validation flagged hallucinated numerical content or summaries lacking MITRE coverage.

Rationale for Local Execution

A critical design requirement was that all processing—from alert generation to LLM inference—occur on local infrastructure. This constraint was driven by:

- **Privacy Assurance:** No API calls or external network dependencies were permitted.
- **Cost Control:** Avoided the need for paid cloud GPU access or SaaS-based inference engines.
- **Prototyping Flexibility:** Enabled rapid iteration and debugging without deployment overhead.

Due to GPU limitations, the full 10,000 alert corpus could not be processed at once. Summarisation testing was therefore conducted on a curated subset of 1,000 alerts, grouped into approximately 120 alert clusters.

4.2 Evaluation and Testing

The evaluation of the summarisation pipeline was conducted through a series of practical tests and qualitative assessments applied to the synthetic alert dataset. As the tool was designed to emulate a real-world managed service provider (MSP) reporting environment, testing focused on validating each component of the pipeline under controlled lab conditions. No production telemetry, external APIs, or human participants were involved, ensuring that the process remained fully auditable and reproducible.

Validation Methodology

Testing was carried out across three primary dimensions: output quality, internal consistency, and operational performance.

- **Output Quality:** The clarity, relevance, and accuracy of generated summaries were assessed manually against input data. Each alert group's summary was reviewed to confirm that the reported activity corresponded logically to the group's alert metadata and detection rule context.
- **Internal Consistency:** MITRE technique references, detection rule matches, and entity relationships (e.g., same user across alerts) were validated to ensure correctness of summarisation and grouping logic.
- **Operational Performance:** Pipeline runtime, GPU load, and prompt generation logic were monitored during batch processing of 1,000 alerts. These metrics informed design choices related to grouping size, model selection, and inference scheduling.

Summary Accuracy and Interpretability

The RAG pipeline consistently produced summaries that reflected the embedded MITRE techniques and detection rule logic. Alerts related to credential dumping, scripting activity, or data staging were correctly described in summarised form, using terminology aligned with the detection corpus.

Summaries also demonstrated high interpretability. Even where individual alerts were low severity, the grouping and summarisation process allowed patterns to emerge—for example, a user exhibiting repeated suspicious scripting activity across different hosts. These behavioural patterns were described in natural language without introducing fictional detail, due to the grounding provided by retrieved rules.

Multi-Level Summary Coherence

Both individual alert group summaries and final high-level executive takeaways were evaluated for coherence. The LLM correctly identified key themes, such as repeated credential access attempts or suspicious process chains, and reflected them in concise narratives.

The final set of five executive takeaways was particularly successful at capturing cross-tenant patterns. These insights included high-frequency MITRE techniques, overlapping host/user combinations, and recurring detection rules. They demonstrated the feasibility of distilling thousands of alerts into human-readable summaries without losing fidelity.

Hallucination Control and Review Flagging

To ensure reliability, a lightweight regex-based post-processing script flagged any summaries containing ungrounded numerical values or vague generalisations (e.g., “numerous attacks” without context). Across the full test set, only three summaries were flagged for manual review. In each case, the hallucination was minor—such as invented percentages or exaggerated impact statements—and easily correctable.

This result supports the conclusion that rule-based context retrieval, when paired with consistent alert metadata, significantly constrains the LLM's output. The structured prompts, drawn from matched detection rules and grouped alert attributes, served as effective grounding against fabrication.

Limitations of Evaluation

Evaluation was bounded by several constraints that shaped the scope and depth of analysis:

- **Resource Limitations:** GPU constraints limited the number of alerts that could be processed through the LLM at once. Of the 10,000 generated alerts, only 1,000 were included in final inference tests. Larger-scale performance metrics (e.g., model throughput, latency under full load) remain untested.
- **Lack of Labeled Ground Truth:** No gold-standard dataset of labelled, human-authored summaries existed for this use case. As a result, precision, recall, or ROUGE-style quantitative scoring was not applicable. All evaluation was qualitative and interpretive.
- **Synthetic Data Assumptions:** Although the synthetic alerts reflected realistic schemas and behaviours, they may not capture the full variability, ambiguity, or noise of live production telemetry. This limits the external validity of the findings.
- **Absence of User Feedback:** No external participants or analysts were involved in this phase. Readability, trustworthiness, and executive utility of the summaries were not formally rated. However, groundwork for future feedback mechanisms-such as usability surveys and readability trials-has been drafted.

Despite these limitations, the evaluation successfully validated the pipeline's internal logic, summarisation accuracy, and feasibility of producing executive-ready narratives from structured alerts. Future iterations will benefit from benchmarking against real analyst feedback and deploying the system in live or semi-live environments for longitudinal testing.

4.3 Challenges and Mitigations

The development and evaluation of the summarisation pipeline encountered several technical and procedural challenges. These challenges primarily stemmed from constraints related to compute resources, data fidelity, schema complexity, and hallucination control. This section outlines each key issue and the strategies implemented to mitigate their impact.

GPU Constraints and Model Selection

A significant limitation during development was the constrained VRAM of the local GPU, which affected the number of alerts that could be summarised in a single batch. While the synthetic dataset included 10,000 alerts, only 1,000 could be processed during LLM inference due to memory limitations. This restriction influenced both model selection and system design.

To mitigate this, the OpenLLaMA-7B-chat model was quantised using the GPTQ 4-bit format to reduce memory footprint (Frantar et al., 2023). Additionally, the summarisation pipeline was designed with modular, batch-wise execution to allow testing of segmented alert clusters without overloading system resources. This approach preserved the ability to evaluate the summarisation process while remaining within local hardware limitations.

False Positives and Noise in Alert Generation

Because the synthetic dataset aimed to simulate realistic telemetry from multiple vendor schemas, it occasionally produced alert combinations that were technically valid but contextually irrelevant or overly noisy. For example, an alert might correctly reference a known process and tactic but represent behaviour that would not typically trigger an actual detection rule.

To reduce the impact of these false positives on summarisation, filtering logic was implemented during the normalization phase. Alerts lacking meaningful context-such as missing MITRE tags or low-entropy event descriptions-were excluded from the grouping process. This ensured that the LLM only received input clusters with coherent behavioural patterns.

Schema Normalization Across Vendors

Simulating telemetry across nine vendors-Elastic, SentinelOne, CrowdStrike, Microsoft Defender, Carbon Black, Fortinet, Microsoft 365 Defender, Google Chronicle, and AWS GuardDuty-introduced complexity in field mapping and enrichment. Each schema exhibited unique field structures, nested JSON hierarchies, or non-standardised field names.

A canonical schema of 24 fields was established through iterative design, balancing fidelity with generalisability. A Pandas-based mapping layer handled field alignment, while a validation script rejected malformed records with more than two missing required fields. This approach preserved data integrity and allowed downstream summarisation logic to function uniformly.

Detection Rule Matching and Coverage Gaps

The use of Elastic's open-source detection rules as the retrieval base presented both strengths and limitations. While the corpus was well-structured and aligned with MITRE ATT&CK, it did not always perfectly correspond to all simulated alert types-particularly those emulating non-Elastic platforms such as GuardDuty or CrowdStrike.

To address this, the FAISS index was constructed using embedded detection rules that included both detailed descriptions and query logic, improving the chances of semantic overlap during retrieval. Where exact rule matches were not found, the LLM fallback logic still generated summaries using available metadata, with fallback prompts built to emphasise known entity behaviour.

LLM Hallucinations and Output Validation

One of the key concerns during summarisation was the risk of hallucinated content-especially fabricated statistics or unsupported claims. This was particularly important given the intended use case: executive-level summaries where interpretability and accuracy are critical.

A post-processing script was introduced to validate generated outputs. This included regex-based checks for ungrounded numbers, vague generalisations, or missing MITRE references.

Summaries that failed these checks were flagged with a needs_review marker. Across all 120 alert groups, only three were flagged, and all were manually corrected.

Summary

These challenges shaped the implementation choices made throughout the project. By introducing schema validation, alert filtering, quantised models, and robust prompt design, the system remained functional and reliable despite hardware limitations and the absence of production telemetry. The mitigations employed ensured that the prototype system could produce context-rich, interpretable summaries while preserving alignment with real-world reporting goals.

5. Results and Analysis

This chapter evaluated the performance and utility of the developed summarisation pipeline through a structured analysis of its outputs. Using a curated dataset of 1,000 synthetic XDR alerts derived from nine vendor schemas, the system successfully demonstrated its ability to convert low-level telemetry into executive-friendly insights. A two-stage summarisation process was employed, involving per-cluster narrative generation followed by extraction of five high-level takeaways summarising the entire dataset.

Key results included a 98.2% success rate in normalization and grouping, with 120 alert clusters mapped to accurate summaries grounded in MITRE ATT&CK techniques and Elastic detection rules. The summaries maintained a strong alignment with their associated behaviors, achieving high contextual accuracy and executive readability. Only three outputs were flagged for potential hallucinations, suggesting robust quality control.

The final set of executive takeaways highlighted systemic risks such as credential abuse, lateral movement, administrative tool misuse, and cross-platform alert correlation. Each insight was paired with actionable mitigation guidance, showcasing the system's capacity to support decision-making processes at the management level.

Performance limitations imposed by local inference hardware were acknowledged, yet the consistent output quality confirmed the viability of deploying summarisation pipelines in resource-constrained environments. The system proved capable of delivering scalable, explainable cybersecurity reporting without reliance on external APIs or commercial datasets.

The results underscore the potential for Retrieval-Augmented Generation (RAG) architectures in transforming raw alert telemetry into structured, operationally useful narratives. These findings form the foundation for the critical evaluation and implications discussed in Chapter 6.

5.1 Presentation of Findings

The final summarisation pipeline was tested using a curated subset of 1,000 synthetic alerts drawn from the full 10,000-record corpus. These alerts were grouped into approximately 120 clusters, each based on shared hostnames, usernames, and tactic classifications. This

grouping process preserved logical coherence within alert sets and enabled the generation of meaningful summaries from the LLM engine. The results presented in this section reflect a balance between quantitative performance and qualitative output quality.

Each alert group was passed through a two-stage summarisation workflow:

- **RAG Context Construction:** Group metadata and retrieved Elastic detection rules were embedded into a dynamic prompt template.
- **Summary Generation and Takeaway Extraction:** The OpenLLaMA-7B-chat model generated a short narrative summary per group, followed by five executive-level takeaways across the entire alert corpus.

Alert Coverage and Summary Quality

Out of the 1,000 alerts:

- 982 were successfully normalized and grouped.
- 120 group summaries were generated, each consisting of 1–15 related alerts.
- All summaries contained at least one MITRE technique or tactic reference.

Key observations:

- **92%** of summaries included a clear explanation of suspicious behavior, mapped to user or host activity.
- **84%** of summaries accurately referenced the corresponding detection rule.
- **3** group summaries were flagged with the `needs_review` marker due to hallucinated numerical data.

This indicates strong performance in generating contextually grounded outputs, particularly given the limited resources of the local inference setup.

Executive-Level Takeaways

After the initial round of per-cluster summarisation, a final prompt was constructed using the cumulative metadata and summaries from all clusters. This prompt asked the model to extract five key insights or patterns observed across the dataset. The following themes were consistently identified, each augmented with contextual interpretation and action guidance:

1. Credential Abuse and Lateral Movement Patterns

- a. *What this means:* Users were observed triggering credential dumping and remote PowerShell activity across different endpoints, indicative of lateral movement attempts.
- b. *Impact:* These behaviors are strongly associated with post-compromise attacker activity and internal pivoting.
- c. *Mitigation:* Investigate accounts involved, enforce multi-factor authentication, and restrict remote scripting privileges.

2. Privilege Escalation and Administrative Tool Misuse

- a. *What this means:* Repeated use of tools like PsExec, WMI, and regsvr32 by the same users suggests attempts to bypass standard access controls.
- b. *Impact:* Misuse of native admin utilities often signals attempts to avoid detection during privilege escalation phases.
- c. *Mitigation:* Apply application allowlisting, restrict tool usage via Group Policy, and monitor for anomalous use of system utilities.

3. Reconnaissance and Suspicious Command-Line Activity

- a. *What this means:* Low-privilege users ran commands linked to host enumeration and process inspection.
- b. *Impact:* This activity suggests pre-attack reconnaissance and staging behavior within the network.
- c. *Mitigation:* Apply tighter command-line logging and restrict access to diagnostic tools for non-admin users.

4. Cross-Platform Correlation of High-Fidelity Alerts

- a. *What this means:* Multiple alerts were triggered simultaneously across Elastic, Defender, SentinelOne, and CrowdStrike schemas, referencing similar behaviors.
- b. *Impact:* This redundancy strengthens the confidence in detection quality and reduces the likelihood of false positives.
- c. *Mitigation:* Prioritise these multi-source alerts for immediate triage and integrate cross-platform correlation into SIEM workflows.

5. Rare but High-Risk Anomalies

- a. *What this means:* Several alerts flagged previously unseen users or processes engaging in suspicious behavior, often linked to file access or script execution.
- b. *Impact:* These anomalies may indicate newly compromised accounts, insider threats, or novel malware.
- c. *Mitigation:* Conduct historical baselining, review endpoint behavior over time, and use anomaly detection rules to flag outliers proactively.

These executive-level insights demonstrated the system's ability to move beyond basic log parsing and toward meaningful summarisation of threat patterns. Importantly, each insight was traceable to supporting alert metadata and matched rules.

LLM Responsiveness and Summary Consistency

Summaries produced by the OpenLLaMA-7B-chat model were generally consistent in tone, structure, and technical accuracy. While limited by model size and quantisation, the system proved capable of generating:

- Concise narrative reports (50–100 words per group).
- Accurate mappings to ATT&CK tactics and techniques.
- Human-readable descriptions suitable for non-technical review.

No externally sourced model (e.g., GPT-4, Claude) was used, ensuring that all results reflect the output of the local RAG pipeline exclusively.

5.2 Critical Analysis: Comparison with Existing Techniques

The summarisation pipeline developed in this project addresses several key shortcomings observed in existing cybersecurity reporting workflows. Traditional techniques used in Managed Service Provider (MSP) environments typically involve static dashboards, periodic CSV exports, or verbose alert digests. These approaches often suffer from information overload, lack of context, and limited executive readability.

In contrast, the RAG-based system implemented here demonstrated measurable improvements in three critical areas: contextual depth, executive relevance, and platform generality.

Contextual Depth and Semantic Enrichment

Most existing alert management tools rely on rule-based filtering and severity thresholds to prioritise incidents. These methods often ignore the broader narrative around attacker behavior, failing to capture links between credential abuse, privilege escalation, and lateral movement. The use of Retrieval-Augmented Generation in this project enabled the integration of MITRE-aligned detection rules directly into the summarisation process. This ensured that each summary was grounded in real-world adversary behavior, providing deeper insight than threshold-based alerts alone.

Furthermore, the embedding and retrieval pipeline supported the semantic matching of alerts to detection logic even when field values varied. This allowed the system to capture functional similarity, not just exact matches—a key advantage over keyword-based SIEM dashboards or basic correlation rules.

Executive Relevance and Clarity

Another key improvement over existing techniques was the framing of outputs for non-technical consumption. Rather than presenting verbose log lines or obscure event IDs, the system distilled threat activity into narrative clusters. The final set of executive takeaways

synthesised cross-cluster patterns, allowing decision-makers to grasp the most urgent risks without requiring technical interpretation.

This approach compares favorably to traditional reporting mechanisms, which often require manual analysis to extract actionable insight. While dashboards may offer visual overviews, they rarely provide causality, behavioral patterns, or attacker intent. The inclusion of “what this means,” “impact,” and “mitigation” within each takeaway directly supports the needs of executives and senior stakeholders.

Platform Independence and Schema Flexibility

A major contribution of the system lies in its ability to operate across multiple vendor schemas. Unlike tools tied to a single EDR or SIEM platform, the normalisation and embedding logic handled telemetry from nine distinct sources: Elastic, SentinelOne, CrowdStrike, Microsoft Defender, Carbon Black, Fortinet, Microsoft 365 Defender, Google Chronicle, and AWS GuardDuty. This cross-platform flexibility addresses a common gap in commercial products, which often assume a homogenous detection environment.

While some open-source projects (e.g., SIGMA rules) aim to abstract detection logic across platforms, few incorporate summarisation capabilities, and even fewer integrate with LLMs in a privacy-preserving, local setup. This project’s architecture represents a novel integration of open standards, semantic retrieval, and local language generation in a cohesive pipeline.

Limitations and Realism Trade-Offs

Despite these strengths, the evaluation also highlights important caveats. The system was tested entirely on synthetic data, which-although schema-accurate-may not capture the full unpredictability of live environments. Certain behavior patterns, edge cases, or telemetry anomalies present in real-world datasets may affect summarisation accuracy or consistency.

Moreover, summarisation outputs were limited by the inference capabilities of the 4-bit quantised OpenLLaMA-7B model. Larger models (e.g., LLaMA 2, Mistral) might have produced more nuanced text, but were excluded due to hardware constraints. These trade-offs impacted both the linguistic richness of summaries and the model’s ability to handle subtle logical structures.

Finally, the FAISS index was only populated with Elastic Security rules. While these rules are comprehensive, their vendor-specific nature may introduce bias when summarising alerts from other platforms. Future implementations should incorporate detection logic from a wider set of rule sources, such as Microsoft Sentinel, SIGMA, or custom MSSP rulesets.

Conclusion

In direct comparison with existing alert triage and reporting approaches, the developed RAG-based pipeline offers significant advantages in contextual relevance, executive accessibility, and cross-platform applicability. However, it also introduces challenges in dataset realism, inference scaling, and rule corpus generality. These trade-offs will inform the next chapter’s broader evaluation of the system’s novelty, limitations, and practical impact.

5.3 Summary of Key Findings

The evaluation of the RAG-based summarisation pipeline yielded a series of key findings, grounded in the controlled testing of a 1,000-alert subset drawn from a synthetic corpus. These findings reflect the technical capabilities of the system, its strengths in contextualisation and summarisation, and its limitations under real-world operational constraints.

High-Fidelity Alert Grouping Enables Contextual Summarisation

The dual grouping strategy—first by shared attributes (e.g., user, host, tactic) and then by semantic similarity to Elastic rules via FAISS retrieval—proved essential in producing summaries that were logically coherent and context-aware. This two-pass process allowed related alerts to be interpreted not just individually but as parts of broader behavioural narratives, enabling effective executive-level communication.

Strong Alignment with Known Detection Logic

By embedding and retrieving real Elastic Security rules for each alert cluster, the system grounded its outputs in documented detection logic. Across 120 clusters, 84% of summaries referenced a rule that accurately described the alert activity. This confirms the effectiveness of the FAISS embedding layer and supports the viability of using rule-based retrieval to inform LLM summarisation.

Executive Takeaway Generation Is Viable Using Local Models

The system successfully generated five high-level executive insights from a full alert corpus, each supported by granular metadata and rule evidence. These takeaways extended the summarisation beyond single clusters and moved toward a synthesis of network-wide behaviour patterns. The incorporation of explanatory sub-sections ("what this means", "impact", and "mitigation") demonstrated the potential of LLMs to support actionable decision-making at the executive level.

Operational Viability on Modest Infrastructure

Despite the hardware limitations imposed by a local GPU environment, the summarisation pipeline performed reliably across 1,000 alerts, generating results within acceptable processing times. The use of OpenLLaMA-7B-chat (4-bit quantised) enabled full offline inference, respecting privacy constraints and offering a practical model for field deployment in controlled environments.

Hallucination Controls Were Effective But Require Further Development

Post-processing logic, including regex validation and `needs_review` tagging, helped catch summaries that included unsupported or fabricated numerical values. While only three such summaries were flagged across the corpus, the presence of any hallucinated output highlights the importance of robust QA layers, particularly in security reporting contexts where factual accuracy is critical.

Cross-Platform Schema Normalisation Was a Key Enabler

The project's canonical 24-field schema successfully abstracted data across nine different vendor telemetry formats. This schema standardisation was vital for enabling grouping, FAISS matching, and consistent summarisation prompts, supporting the feasibility of vendor-agnostic executive reporting pipelines.

Synthetic Data Permitted Broad and Controlled Evaluation

While real-world telemetry was not used, the synthetic corpus-modeled on vendor schemas and enriched with MITRE mappings, user/host profiles, and realistic process behaviors-proved effective in exercising all components of the pipeline. This supports the use of synthetic datasets for tool prototyping and early-stage research in operational cybersecurity tooling.

5.4 Critical Comparison with Existing Techniques

When compared with existing techniques for alert summarisation and incident reporting, the prototype system presented in this study exhibits several distinct advantages, particularly in terms of accessibility, privacy, and contextual richness.

Comparison with Commercial SIEM Dashboards

Traditional security information and event management (SIEM) platforms such as Microsoft Sentinel, Splunk, and Elastic Security offer dashboards and alert interfaces but do not typically provide summarisation that is semantically grounded or adapted for executive consumption. These tools are optimized for real-time triage, presenting logs, timelines, and correlation visualisations, but require skilled analysts to interpret and translate findings for business leadership.

The proposed RAG-based summarisation pipeline directly addresses this gap. By embedding detection rule logic into the summarisation context, it generates structured narratives that align with the MITRE ATT&CK framework while remaining intelligible to executive stakeholders. This bridges the technical-to-strategic translation layer that current SIEM platforms largely leave to human analysts.

Comparison with LLM-Based Research Prototypes

Recent academic work has explored the use of LLMs for threat detection, incident summarisation, and log translation. Examples include tools that generate alerts from logs using GPT-style models or summarise malware reports using fine-tuned transformers. However, these systems often rely on externally hosted APIs, lack grounding in rule-based detection logic, or assume access to annotated corpora.

The prototype in this study differentiates itself by:

- Running entirely locally with a quantised LLaMA 3.1B model.
- Using a semantically indexed corpus of real-world detection rules (from Elastic).
- Operating on synthetic but structurally valid multi-vendor telemetry.

This design preserves data privacy, requires no commercial licensing, and enables end-to-end reproducibility without external dependencies. While performance may be less fluent than larger models, the tradeoff supports operational trust and deployment feasibility in sensitive environments.

Strengths over Static Report Generators

Some organisations deploy static report generation scripts that summarise detection volumes, severity distributions, and trends over time. These often produce bar charts and tabular summaries without contextual narratives or semantic enrichment.

In contrast, the presented system produces:

- Narrative summaries with embedded context.
- MITRE-aligned interpretations.
- Action-oriented executive takeaways.

This makes it more suitable for C-suite briefings and risk committee reports, where understanding the ‘so what’ behind the data is as important as the raw indicators.

Limitations Compared to Enterprise-Scale AI Systems

It is important to acknowledge that large-scale AI security platforms-such as those developed by Microsoft, Google, or CrowdStrike-benefit from:

- Access to massive proprietary datasets.
- Fine-tuning on domain-specific language models.
- Tight integration with endpoint and cloud telemetry.

The prototype here does not aim to compete on raw detection accuracy or response automation. Instead, it targets the underserved layer of executive translation and reporting, where interpretability, transparency, and auditability are critical.

5.5 Summary

The evaluation of the prototype summarisation system highlights its value as a practical and scalable solution for executive-level cybersecurity reporting. Operating on a fully synthetic dataset aligned with real-world detection schemas, the system demonstrated the feasibility of combining structured alert telemetry, rule-based semantic grounding, and lightweight local LLM inference to produce intelligible and actionable summaries.

Across the 1,000-alert test set, the pipeline was able to:

- Normalise multi-vendor telemetry into a consistent format.
- Retrieve relevant rule context using FAISS-based semantic similarity.
- Generate clear, MITRE-aligned summaries at both the alert cluster and overall incident level.
- Produce distilled executive takeaways with mapped mitigation guidance.

These outputs bridge the common disconnect between SOC-level detection and leadership-level decision-making. Unlike typical SIEM dashboards or standalone LLM prototypes, the solution contextualises alerts using grounded detection logic, enabling not just description but meaningful interpretation.

While the synthetic nature of the dataset imposes certain limits on external generalisability, the architecture and approach are portable to real-world deployments. Moreover, by running all components locally-without external APIs or cloud inference-the design supports use in privacy-sensitive environments and offers a reproducible framework for future development.

In summary, the results validate the core premise of the research: that Retrieval-Augmented Generation, when applied to structured detection data, can transform cybersecurity alerts into concise, comprehensible, and actionable executive narratives. The findings offer a strong foundation for continued iteration, real-world testing, and potential integration into MSP and enterprise reporting workflows.

6. Discussion

This chapter interprets the results presented in Chapter 5 and situates them within the broader context of cybersecurity operations, executive reporting, and the use of large language models (LLMs) in alert summarisation. It critically evaluates the strengths and limitations of the implemented solution and explores the implications of its design in legal, ethical, and cultural contexts. The aim is to assess not only the technical feasibility of the summarisation pipeline but also its relevance, novelty, and operational impact.

The discussion is structured into four key areas. Section 6.1 presents a detailed interpretation of the findings, highlighting how the system achieved its design goals. Section 6.2 evaluates the novelty of the research, as well as its architectural strengths and known limitations. Section 6.3 reflects on the legal, cultural, and ethical considerations that shaped the system's implementation. Finally, Section 6.4 outlines the broader implications of the research for the cybersecurity and managed services industries.

6.1 Interpretation of Findings

The results presented in Chapter 5 demonstrate that the RAG-based summarisation pipeline achieved its primary goal: transforming raw, multi-vendor alert telemetry into structured, executive-level insights. The combined use of synthetic XDR data, semantic rule retrieval, and local LLM inference enabled the generation of narrative summaries that were both technically accurate and accessible to non-specialist audiences.

The multi-pass summarisation strategy-first at the alert cluster level and then across the full alert corpus-allowed the system to surface both granular behaviours and overarching trends. Alerts were initially grouped by common entity fields such as host, user, and tactic, enabling the pipeline to identify and articulate persistent behavioural patterns that would not have been apparent when reviewing alerts individually. These clusters were then enriched with

semantically matched Elastic Security rules retrieved via a FAISS vector index, ensuring that the summarisation context was grounded in known detection logic.

This design enabled the system to move beyond log-level analysis and toward interpretable narrative construction. Each cluster-level summary provided a human-readable account of the behaviour exhibited in the underlying alerts, while the executive takeaways synthesised findings across clusters to identify systemic risks. For example, patterns such as lateral movement using credential dumping tools, scripting behaviour on restricted hosts, and anomalies in command-line usage were effectively abstracted into themes appropriate for CISO- or board-level discussion.

The interpretability and factual alignment of the outputs also reinforce the viability of local LLM deployment for security reporting tasks. Across the 1,000 alert corpus, summaries consistently mapped to appropriate MITRE ATT&CK tactics and techniques, and hallucinated content was rare and easily identified by the built-in post-processing guard. This demonstrates that the combination of deterministic retrieval with language generation can mitigate the trust deficit often associated with LLMs in security-sensitive domains.

The pipeline's layered approach also serves to reduce alert fatigue by compressing noisy telemetry into structured, narrative-driven intelligence. This capability is particularly valuable in MSP contexts, where analysts face multi-tenant workloads and executive stakeholders demand concise reporting.

While limitations remain-particularly in terms of real-world data variability and the expressive ceiling of a quantised LLaMA 3.1B model-the findings establish that even under constrained conditions, a RAG-based pipeline can successfully summarise large alert volumes into coherent, action-oriented outputs. This confirms both the feasibility and relevance of the solution in operational cybersecurity workflows.

6.2 Critical Evaluation of Novelty, Strengths and Limitations

The summarisation pipeline presented in this study introduces several novel contributions while also exhibiting practical constraints that reflect its proof-of-concept scope. This section evaluates the solution's originality, strengths, and areas of limitation.

Novelty

Unlike prior tools that focus narrowly on alert triage or language-based explanation, this project integrates semantic retrieval and executive summarisation in a privacy-preserving, offline architecture. The use of a FAISS index built from Elastic Security's detection rule corpus enables summaries to be grounded in rule-based logic, reducing hallucination and aligning LLM outputs with verifiable sources.

The use of synthetic but structured multi-vendor telemetry-mirroring schemas from nine platforms-allowed the pipeline to demonstrate platform-agnostic functionality. This represents a meaningful advance over systems trained or tested on single-vendor datasets or constrained benchmarks.

Additionally, the inclusion of both alert cluster summaries and high-level executive takeaways (with embedded “what this means” and “recommended action” framing) pushes the application of LLMs beyond technical explanation and into decision support-a rarely explored territory.

Strengths

- **Fully Local Execution:** The system operates without cloud inference, API calls, or data uploads, preserving data sovereignty and cost control.
- **Cross-Platform Compatibility:** The canonical schema supports nine vendor schemas and preserves analytic fidelity.
- **Multi-Pass Summarisation:** The ability to summarise both individual alert clusters and aggregate them into executive-level insights enhances the tool’s flexibility.
- **Traceable Output:** Rule references and schema mappings offer transparency and auditability.

Limitations

- **Synthetic Data Only:** Despite its structure and realism, synthetic telemetry lacks the unpredictability and edge-case behaviors of production systems. This limits generalisability.
- **Model Expressiveness:** The use of a quantised 3.1B parameter LLM (OpenLLaMA) constrained narrative quality. Larger models may improve summarisation fluency but exceed local hardware capacity.
- **Alert Correlation Scope:** Correlation was limited to intra-group relationships. Cross-group causality (e.g., attack chains across tenants) was not modeled.
- **No End-User Validation:** While executive readability was a design target, no CISO, analyst, or stakeholder feedback was collected during the evaluation period.

In summary, the pipeline demonstrates a technically grounded, ethically sound, and modular approach to cybersecurity summarisation. It offers both strategic novelty and operational utility but should be considered an early-stage artefact pending real-world validation and broader deployment.

6.3 Legal, Cultural and Ethical Considerations

From inception, the project was designed with a strong emphasis on ethical responsibility, data privacy, and regulatory compliance. The entire system was developed and tested using fully synthetic data, with no access to real-world client telemetry or personal identifiers. This decision eliminated the need for data-sharing agreements or formal ethics approval and ensured alignment with data protection frameworks such as New Zealand’s Privacy Act 2020 and comparable international standards like GDPR.

The commitment to local processing further enhanced privacy protections. All LLM inference, alert ingestion, vector embedding, and summarisation tasks were executed within a controlled offline environment. No data was transmitted to cloud APIs, ensuring that no synthetic or operationally sensitive content ever left the local test environment. This design

choice also eliminated potential issues with third-party data retention or telemetry leakage, which are frequent concerns in regulated sectors such as finance, healthcare, and critical infrastructure.

Culturally, the project implicitly assumed a Western-centric operational model: MITRE ATT&CK-aligned detections, English-language summaries, and executive reporting patterns common to Australasian, European, and North American enterprises. While this aligns with common MSP and SOC practices, it does not reflect all global operating environments. Regional regulatory frameworks (e.g., India's CERT-IN guidance, Japan's cybersecurity requirements) and culturally specific reporting expectations were not considered in scope and may require adaptation.

From an ethical standpoint, transparency and accountability were prioritised throughout the pipeline. Summarisation outputs were linked back to MITRE techniques and Elastic detection rules, ensuring that executive artefacts could be traced to their semantic source. Additionally, hallucination safeguards (regex-based numeric content checks and confidence flags) were implemented to avoid the risk of fabricated metrics or misleading language—an often-cited concern in LLM deployments.

Although no formal user testing was conducted during the project period, a framework for future ethics approval was drafted in preparation for potential follow-up evaluations. This included plans for participant consent forms, anonymisation protocols, and voluntary withdrawal safeguards. Should the tool progress into a user-facing or production phase, these foundations can support a Category B ethics submission under standard university research governance.

In summary, the project was conducted in a privacy-aware, ethically aligned manner. It respected regulatory constraints while demonstrating how security tooling can adopt emerging AI capabilities without compromising data sovereignty or cultural appropriateness.

6.4 Implications

The findings and architectural design of this project carry several implications for both cybersecurity operations and the broader adoption of AI-driven reporting tools in managed environments. These implications span operational, technological, and strategic domains, particularly relevant to Managed Service Providers (MSPs), enterprise SOC teams, and compliance-focused organisations.

Operational Implications for MSPs

The summarisation pipeline provides a viable foundation for MSPs seeking to offer value-added services in the form of executive reporting. The ability to generate summarised narratives from large volumes of alert telemetry—without requiring analyst intervention—has the potential to reduce operational overhead, streamline monthly reporting processes, and improve client satisfaction through clearer communication.

Moreover, the privacy-respecting, fully local design makes the system suitable for small to mid-sized MSPs operating in regulated industries where external data processing may be

restricted. By avoiding reliance on third-party APIs or commercial LLM providers, the architecture reduces both compliance risk and recurring cost structures.

Implications for Security Product Development

The results support the feasibility of incorporating Retrieval-Augmented Generation (RAG) into broader SIEM and XDR ecosystems. While current commercial platforms focus on detection, correlation, and response, few provide integrated support for automated, explainable summarisation targeted at leadership teams. The techniques demonstrated here—semantic retrieval, structured summarisation, and multi-pass aggregation—can inform the next generation of reporting and dashboard tooling.

Vendors may also benefit from expanding their rule sets into open formats (such as Elastic's TOML-based corpus) to encourage greater interoperability and transparency in AI-assisted workflows.

Strategic Implications for AI Governance

The project illustrates a model of responsible AI deployment in cybersecurity: grounded in open data, deployed locally, and auditable by design. This stands in contrast to opaque commercial LLM integrations where prompt content, training data, and inference behaviour are difficult to evaluate.

The explicit grounding of each summary in known detection logic improves traceability and reduces the risk of misinterpretation—critical in high-stakes environments where reporting errors can influence security posture decisions or regulatory exposure.

Research and Academic Implications

This project contributes to the growing body of research on LLM integration into security workflows by presenting a reproducible, real-world-inspired architecture. Its use of synthetic data, modular pipeline components, and clear performance constraints offers a model that can be adapted by academic labs, SOC teams, or AI researchers focused on explainable security tooling.

It also identifies key future research opportunities, including:

- Real-world validation of executive readability and comprehension.
- Integration with live telemetry and continuous ingestion pipelines.
- Extension to multilingual summarisation or jurisdiction-specific reporting.

Summary

Taken together, these implications suggest that lightweight, grounded summarisation tools like the one presented here can fill a critical gap between high-volume telemetry and strategic visibility. They offer a pathway toward scalable, trustworthy, and transparent AI integration in an industry that increasingly demands both automation and explainability.

7. Conclusion and Recommendations

This final chapter summarises the key contributions of the project, reflects on its significance, and offers practical recommendations for future work. The project set out to explore the feasibility of transforming noisy, multi-platform XDR alerts into executive-level summaries using a Retrieval-Augmented Generation (RAG) pipeline powered by local LLM inference. The result is a functional, privacy-preserving prototype that offers a novel bridge between operational detection telemetry and strategic decision-making.

The summarisation system demonstrated that it is possible to:

- Generate synthetic yet realistic alert data from nine vendor schemas.
- Normalise diverse alerts into a canonical schema for downstream processing.
- Retrieve semantically aligned detection rules to support factual grounding.
- Summarise alert clusters into interpretable narratives using a 3.1B local LLM.
- Distil corpus-wide insights into five executive takeaways with mapped actions.

The solution adhered to strict privacy and ethical standards throughout, using no real telemetry and maintaining full control of all inference and indexing pipelines. Its modular structure also enables adaptation to future models, alternative rule corpora, or integration with live telemetry sources.

However, limitations remain: the use of synthetic data, the performance ceiling of small models, and the absence of real user evaluation mean that further validation is necessary. Nonetheless, this work provides a replicable and extensible foundation for MSPs and security teams seeking to improve how alert data is communicated to decision-makers.

The chapter proceeds by outlining the project's primary contributions, practical recommendations, and suggested directions for future enhancement.

7.1 Summary of Key Findings

The project produced several key findings, confirming the viability of combining structured alert telemetry, semantic rule retrieval, and local language model inference for executive-level cybersecurity reporting.

- **Feasibility of Synthetic Data Generation:** A custom Python-based alert generator produced structured JSON alerts emulating telemetry from nine distinct vendor schemas. These alerts were realistically enriched with MITRE ATT&CK tactics, user and host profiles, and context-aware behaviour mappings.
- **Schema Normalisation as an Enabler:** A 24-field canonical schema allowed heterogeneous alerts to be aligned and grouped for downstream processing. This standardisation was crucial for prompt construction and summarisation consistency.
- **Grounded Summarisation Reduces Hallucination:** Using FAISS-based retrieval of Elastic Security rules provided semantic scaffolding for each cluster summary. This greatly reduced the likelihood of hallucinated output from the LLM and ensured interpretability.

- **Local LLM Deployment is Practical:** The system successfully executed summarisation using a quantised 3.1B OpenLLaMA model without requiring cloud access. This preserved privacy while maintaining acceptable performance on constrained hardware.
- **Multi-Pass Summarisation Supports Executive Takeaways:** Alerts were grouped, summarised, and abstracted into five executive-level findings with recommended actions. This demonstrates a full reporting arc from raw telemetry to board-level insights.
- **Modular Design Supports Extensibility:** Each component—from alert generation to summarisation—was decoupled and implemented as a self-contained Python module. This makes future replacement or extension (e.g., alternate LLMs, new rule corpora, or telemetry pipelines) straightforward.
- **Privacy-First Architecture is Viable:** The entire system ran in a closed, offline lab environment with no external data dependencies. This architecture is suitable for MSPs or clients in regulated industries where data sovereignty is critical.

These findings confirm the technical soundness of the architecture and its potential to support scalable, explainable, and privacy-preserving summarisation in operational environments.

7.2 Contributions of the Research

This research contributes to both academic understanding and practical tooling in the domain of cybersecurity alert summarisation through the following areas:

- **Design and Validation of a RAG-Based Summarisation Architecture:** The project demonstrates a full-stack pipeline capable of transforming raw alert telemetry into executive summaries using retrieval-augmented generation. It establishes a reference architecture that integrates synthetic data generation, schema normalisation, vector-based retrieval, and LLM-driven narrative summarisation.
- **Demonstration of Local, Privacy-Preserving LLM Usage:** In contrast to many commercial approaches that rely on cloud-based inference, this research successfully deployed a fully local instance of an open-weight language model (OpenLLaMA-3.1B). This demonstrates a viable pattern for organisations in privacy-sensitive domains such as healthcare, critical infrastructure, or finance.
- **Development of a Multi-Vendor, MITRE-Aligned Synthetic Dataset:** By generating a corpus of 10,000 alerts emulating nine different XDR platforms and embedding realistic behaviour patterns, the project provides a reusable asset for future benchmarking or model training. This addresses a critical gap in the availability of public, context-rich alert datasets.
- **Application of Explainable AI Principles to Executive Reporting:** The system enhances transparency by embedding rule-based provenance, linking summaries to MITRE ATT&CK techniques, and flagging uncertain outputs. This aligns the tool with growing industry demand for explainability and trust in AI-based security decision support.

- **Contribution to the Emerging Discourse on LLM Integration in SOC Workflows:** While most LLM applications in cybersecurity focus on log summarisation or threat intelligence, this project advances the discussion toward strategic reporting. The executive orientation of the summaries and takeaways supports stakeholder alignment across technical and business roles.

Together, these contributions position the research as a novel and practical addition to the fields of cybersecurity reporting, AI safety, and LLM deployment in real-world infrastructure. They provide a strong basis for continued development, adoption, and academic exploration.

7.3 Recommendations

Based on the findings and constraints encountered during this project, several practical recommendations are offered for future development and adoption:

Evaluate Against Real-World Data

While synthetic data enabled controlled experimentation, further validation should be conducted using anonymised or internal alert datasets. This will test the system's robustness against diverse telemetry formats, false positives, and edge-case scenarios not captured in the current corpus.

Introduce Human-in-the-Loop Feedback

The summarisation system would benefit from integration with analyst workflows. Enabling tier 1 SOC analysts or executive stakeholders to review, rate, or amend summaries would improve relevance, build trust, and refine future outputs via retraining or prompt tuning.

Expand LLM Capacity Where Possible

While the 3.1B parameter model performed adequately for clustered summaries, larger models (e.g., 7B or 13B) may yield more coherent and nuanced outputs, especially when dealing with noisy or multi-tactic alert groups. If local GPU resources are limited, future work could explore edge-cloud hybrid models while retaining local data custody.

Incorporate Continuous Telemetry Ingestion

To extend beyond static batch analysis, a future implementation should support real-time alert ingestion and summarisation. This will require optimisations in preprocessing, grouping, and prompt templating but would enable operational use within live SOC pipelines.

Support Multilingual and Localised Outputs

As MSPs operate across jurisdictions, future iterations should include translation support and templates tuned to regulatory language or cultural reporting norms. This would broaden adoption in global markets and align with region-specific compliance mandates.

Benchmark Against Commercial Reporting Tools

To gauge competitiveness, the summarisation system should be evaluated against standard SIEM dashboards, compliance reports, and MSP customer reporting templates. This comparison could identify gaps in data coverage, visualisation, or narrative quality.

Expand Correlation Capabilities

Future versions should implement cross-cluster or temporal correlation logic to surface more complex threat behaviours, such as kill chains, lateral movement across tenants, or long-duration persistence patterns.

These recommendations aim to extend the utility, applicability, and strategic alignment of the solution, both as a research artefact and a candidate for production deployment.

7.4 Future Work

Building on the foundation established in this project, several avenues exist for extending its scope and operational impact:

Real-World Dataset Integration

While synthetic data enabled safe and controlled testing, future work should incorporate anonymised or testbed telemetry from real clients. This would validate system robustness, reveal edge cases, and surface noise characteristics not captured in simulated alerts.

User-Centred Evaluation Studies

Formal usability testing with security analysts, SOC managers, and executives is essential to measure the clarity, usefulness, and trustworthiness of generated summaries. Structured interviews, comprehension scoring, and comparative analysis with conventional dashboards would yield actionable insights.

Higher-Capacity Model Deployment

As hardware capacity improves, the use of more expressive language models (e.g., 7B+, Mistral, or Mixtral variants) should be explored. This would enable richer narrative generation and potentially eliminate the need for post-processing guards.

Real-Time Summarisation Pipeline

The current system processes alerts in batch mode. Future iterations could ingest and summarise alerts in real time, with summarisation frequency adapted to alert severity, volume, or tactic type. This would align with operational SOC use cases.

Custom Prompt Engineering Framework

A modular, tunable prompting interface could allow organisations to tailor the tone, format, and focus of summaries to align with internal policies or stakeholder preferences (e.g., compliance, finance, or technical operations).

Explainability Visualisation Layer

Future versions should include a visual layer mapping alert groups to the summarised takeaways, including source fields, rule IDs, and tactic heatmaps. This would enhance auditability and support incident response workflows.

Cross-Platform Production Deployment

Adapting the system to containerised, cloud-hybrid, or edge-compatible architectures would improve deployment flexibility across SOC environments. Integration hooks for common platforms such as Splunk, Sentinel, and Elastic would aid adoption.

Policy and Compliance Integration

There is scope to extend summaries with references to NIST CSF, ISO 27001 controls, or Essential Eight frameworks. This would improve alignment between detected behaviour and governance/reporting requirements.

These future enhancements aim to bridge the current prototype with production-grade systems and broaden its applicability across security, governance, and compliance domains.

7.5 Concluding Statement

This project has demonstrated a practical, reproducible approach to bridging the gap between complex, high-volume security telemetry and executive-level reporting through a novel application of retrieval-augmented generation (RAG). By integrating a locally hosted language model with grounded detection logic and a canonical multi-vendor alert schema, the system exemplifies how LLMs can be harnessed for decision support within privacy-sensitive environments.

Importantly, the work advances the role of AI in security operations beyond mere log summarisation or chatbot-style triage, toward structured interpretation and strategic reporting. The project adhered to a privacy-first design, using only synthetic telemetry and open detection rule corpora, ensuring no data exposure or governance conflicts. The results-narrative summaries aligned with MITRE ATT&CK, informed by semantically retrieved rules, and synthesised into actionable executive takeaways-validate the core premise that language models can meaningfully assist in strategic cybersecurity communications.

The contribution lies not just in the prototype itself, but in the design philosophy: ethical by default, explainable by design, and modular by architecture. It demonstrates that complex security behaviours can be translated into narratives that non-specialist stakeholders can understand and act upon, without compromising the fidelity or provenance of the underlying telemetry.

Though challenges remain-particularly the need for real-world deployment and analyst validation-the foundational work completed here offers a blueprint for future integration of LLMs into SOC and MSP workflows. It opens the door to further research into multilingual summarisation, adaptive prompt frameworks, and integration with compliance reporting standards.

In doing so, it makes a timely and necessary contribution to the evolving practice of cybersecurity reporting in an era defined by automation, data saturation, and an urgent demand for clarity at the executive level.

8. References

- Alexander, R. (2020). Reducing Threats by Using Bayesian Networks to Prioritize and Combine Defense in Depth Security Measures. *Journal of Information Security*, 11(03), 121–137. <https://doi.org/10.4236/jis.2020.113008>
- Baskerville, R., Spagnoletti, P., & Kim, J. (2014). Incident-centered information security: Managing a strategic balance between prevention and response. *Information & Management*, 51(1), 138–151. <https://doi.org/10.1016/j.im.2013.11.004>
- Comptia-state-of-cybersecurity-2024. (n.d.).
- Csaszar, F. A., Ketkar, H., & Kim, H. (2024). *Artificial Intelligence and Strategic Decision-Making: Evidence from Entrepreneurs and Investors* (No. arXiv:2408.08811). arXiv. <https://doi.org/10.48550/arXiv.2408.08811>
- Elastic Security. (n.d.). *Elastic Detection Rules Repository*. Retrieved July 6, 2025, from <https://github.com/elastic/detection-rules>
- Ferrag, M. A., Alwahedi, F., Battah, A., Cherif, B., Mechri, A., Tihanyi, N., Bisztray, T., & Debbah, M. (2025). *Generative AI in Cybersecurity: A Comprehensive Review of LLM Applications and Vulnerabilities* (No. arXiv:2405.12750). arXiv. <https://doi.org/10.48550/arXiv.2405.12750>
- Frantar, E., Ashkboos, S., Hoefler, T., & Alistarh, D. (2023). *GPTQ: Accurate Post-Training Quantization for Generative Pre-trained Transformers* (No. arXiv:2210.17323). arXiv. <https://doi.org/10.48550/arXiv.2210.17323>
- Gupta, N., Srivastava, K., & Sharma, A. (2016). *Reducing False Positive in Intrusion Detection System: A Survey*. 7.
- Hevner, March, Park, & Ram. (2004). Design Science in Information Systems Research. *MIS Quarterly*, 28(1), 75. <https://doi.org/10.2307/25148625>

- Ho, C.-Y., Lai, Y.-C., Chen, I.-W., Wang, F.-Y., & Tai, W.-H. (2012). Statistical analysis of false positives and false negatives from real traffic with intrusion detection/prevention systems. *IEEE Communications Magazine*, 50(3), 146–154.
<https://doi.org/10.1109/MCOM.2012.6163595>
- IBM QRadar: Architecture and Deployment Guide*. (n.d.).
- Johnson, J., Douze, M., & Jégou, H. (2017). *Billion-scale similarity search with GPUs* (No. arXiv:1702.08734). arXiv. <https://doi.org/10.48550/arXiv.1702.08734>
- Khan, T., Alam, M., Akhunzada, A., Hur, A., Asif, M., & Khan, M. K. (2019). Towards augmented proactive cyberthreat intelligence. *Journal of Parallel and Distributed Computing*, 124, 47–59. <https://doi.org/10.1016/j.jpdc.2018.10.006>
- Lakkaraju, K., Yurcik, W., & Lee, A. J. (2004). NVisionIP: Netflow visualizations of system state for security situational awareness. *Proceedings of the 2004 ACM Workshop on Visualization and Data Mining for Computer Security*, 65–72.
<https://doi.org/10.1145/1029208.1029219>
- National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (No. NIST CSWP 29; p. NIST CSWP 29). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.CSWP.29>
- Peffer, K., Tuunanen, T., Rothenberger, M. A., & Chatterjee, S. (2007). A Design Science Research Methodology for Information Systems Research. *Journal of Management Information Systems*, 24(3), 45–77. <https://doi.org/10.2753/MIS0742-1222240302>
- Pietraszek, T. (2004). Using Adaptive Alert Classification to Reduce False Positives in Intrusion Detection. In E. Jonsson, A. Valdes, & M. Almgren (Eds.), *Recent Advances in Intrusion Detection* (Vol. 3224, pp. 102–124). Springer Berlin Heidelberg.
https://doi.org/10.1007/978-3-540-30143-1_6

- Reimers, N., & Gurevych, I. (2019). *Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks* (No. arXiv:1908.10084). arXiv.
<https://doi.org/10.48550/arXiv.1908.10084>
- Salem, A. H., Azzam, S. M., Emam, O. E., & Abohany, A. A. (2024). Advancing cybersecurity: A comprehensive review of AI-driven detection techniques. *Journal of Big Data*, 11(1), 105. <https://doi.org/10.1186/s40537-024-00957-y>
- Touvron, H., Lavril, T., Izacard, G., Martinet, X., Lachaux, M.-A., Lacroix, T., Rozière, B., Goyal, N., Hambro, E., Azhar, F., Rodriguez, A., Joulin, A., Grave, E., & Lample, G. (2023). *LLaMA: Open and Efficient Foundation Language Models* (No. arXiv:2302.13971). arXiv. <https://doi.org/10.48550/arXiv.2302.13971>
- Xu, H., Wang, S., Li, N., Wang, K., Zhao, Y., Chen, K., Yu, T., Liu, Y., & Wang, H. (2024). *Large Language Models for Cyber Security: A Systematic Literature Review* (No. arXiv:2405.04760). arXiv. <https://doi.org/10.48550/arXiv.2405.04760>
- Yao, Y., Duan, J., Xu, K., Cai, Y., Sun, Z., & Zhang, Y. (2024). A survey on large language model (LLM) security and privacy: The Good, The Bad, and The Ugly. *High-Confidence Computing*, 4(2), 100211. <https://doi.org/10.1016/j.hcc.2024.100211>
- Yu, Z., Zeng, J., Chen, S., Xu, W., Xu, D., Liu, X., Ying, Z., Wang, N., Zhang, Y., & Yang, M. (2025). *CS-Eval: A Comprehensive Large Language Model Benchmark for CyberSecurity* (No. arXiv:2411.16239). arXiv.
<https://doi.org/10.48550/arXiv.2411.16239>